

IT Infrastructure Overview Assessment Report

**By Aung Myint, IT Admin,
CISSP, CCSP, PNPT, M.Sc.**

August 26th, 2024



This page is intentionally left blank.

Table of Contents

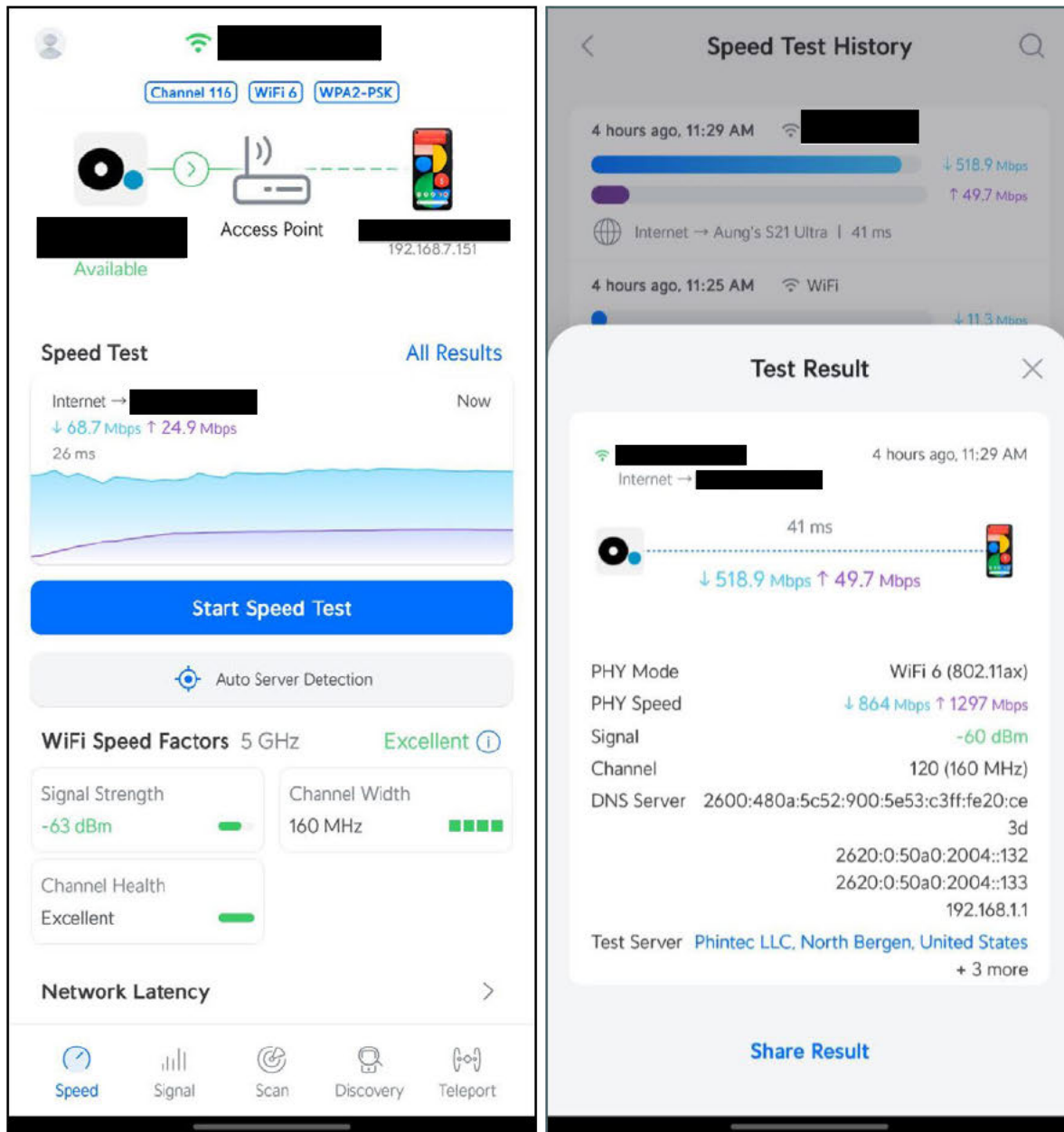
Introduction	4
Wi-Fi Internet Speed and Signal Strength Analysis.....	5
Wi-Fi Security Analysis.....	11
Wireless Network Implementation Analysis.....	12
Wired Network Implementation Analysis.....	13
Internet Outage Analysis	14
Network Infrastructure Analysis	15
Office Phone System Implementation Analysis	17
Networking Devices and Server Locations Analysis	19
Software and Applications Analysis	21
Database and Data Management Analysis	22
Website Analysis	24
IT Devices Supply Chain and Disposal Analysis	25
IT Inventory and Storage Analysis	26
Analysis of Frequently Reported User Issues and Ticketing System Performance in Recent Years	27
Centralized Device Management Analysis	29
Business Continuity and Disaster Recovery (BC/DR) Analysis.....	35
IT Department Standards and Policies Analysis.....	37
Physical and Perimeter Security Analysis	38
Security Awareness Analysis.....	40
Additional Recommendations for Improvement	43



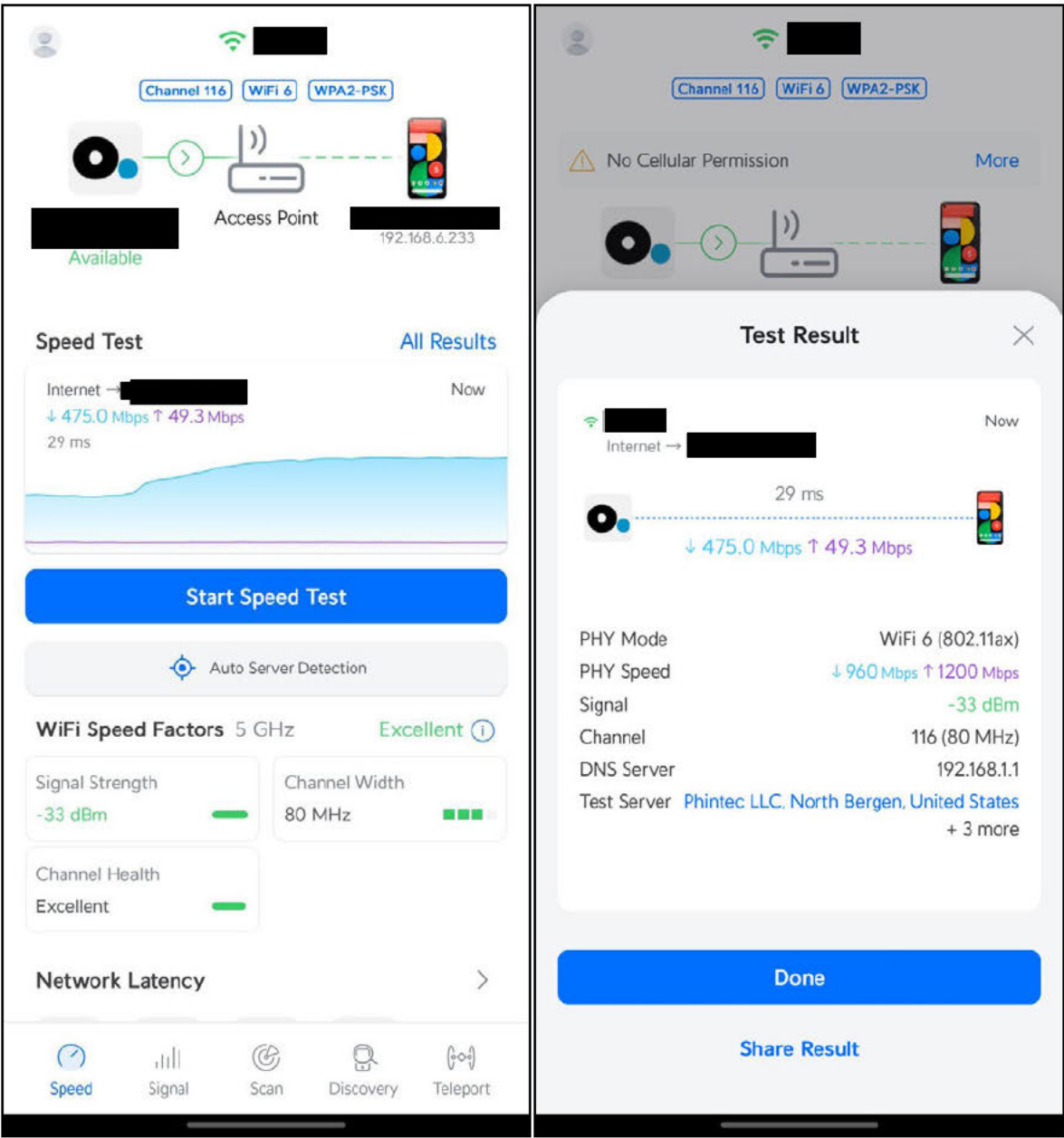
Introduction

- ❖ This assessment report provides an overview of the IT infrastructure, with a light touch on security considerations.
- ❖ The report focuses on a high-level analysis, and it covers many areas and highlights key areas for improvement. To thoroughly address each topic, a benefit and cost analysis, along with a pros and cons assessment, will be necessary.
- ❖ Security is not the primary focus of this assessment. For a comprehensive evaluation of information security, separate, detailed security and risk assessment reports will be necessary.
- ❖ Some topics covered in this report will require further investigation, including consultations with other departments or third-party companies to gain a more detailed understanding of the infrastructure setup.
- ❖ This report is intended for executives to provide insights into the status of the IT department, identify areas for improvement, and anticipate future projects.
- ❖ This report is essential because it allows us to reflect on our highest achievements, enabling us to build the infrastructure from the ground up more effectively.

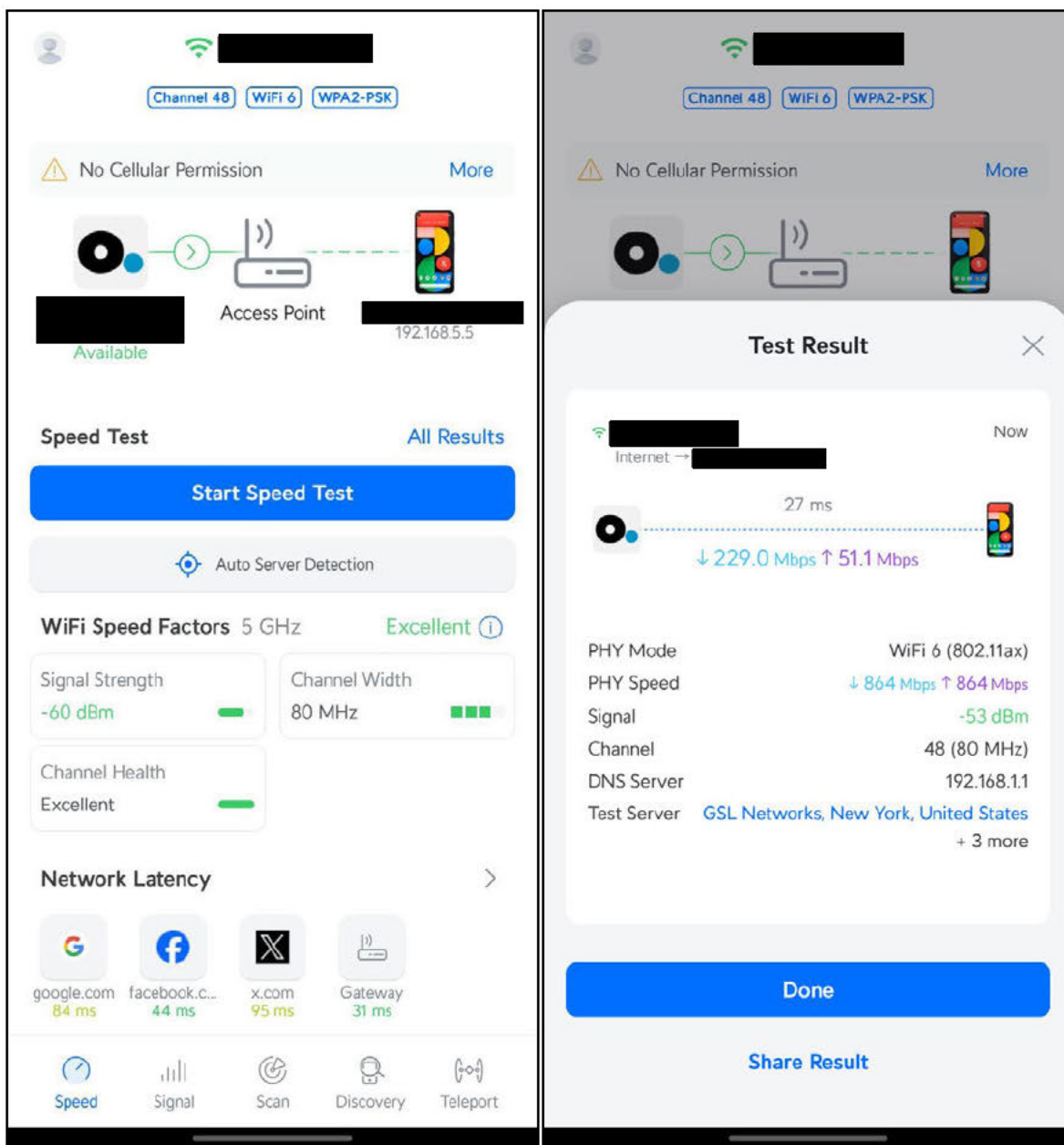
Wi-Fi Internet Speed and Signal Strength Analysis



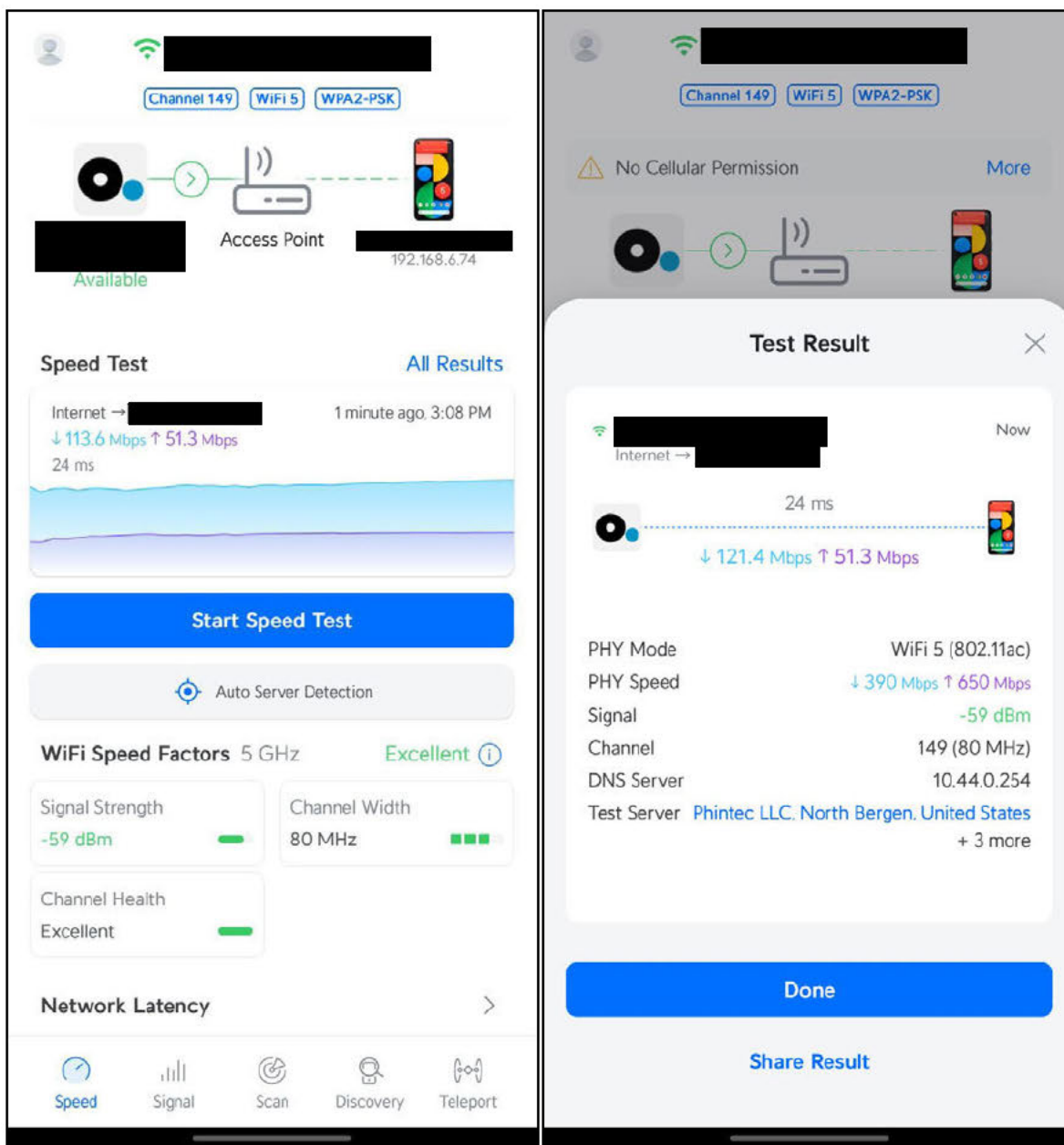
Wi-Fi test result



Wi-Fi test result



Wi-Fi test result



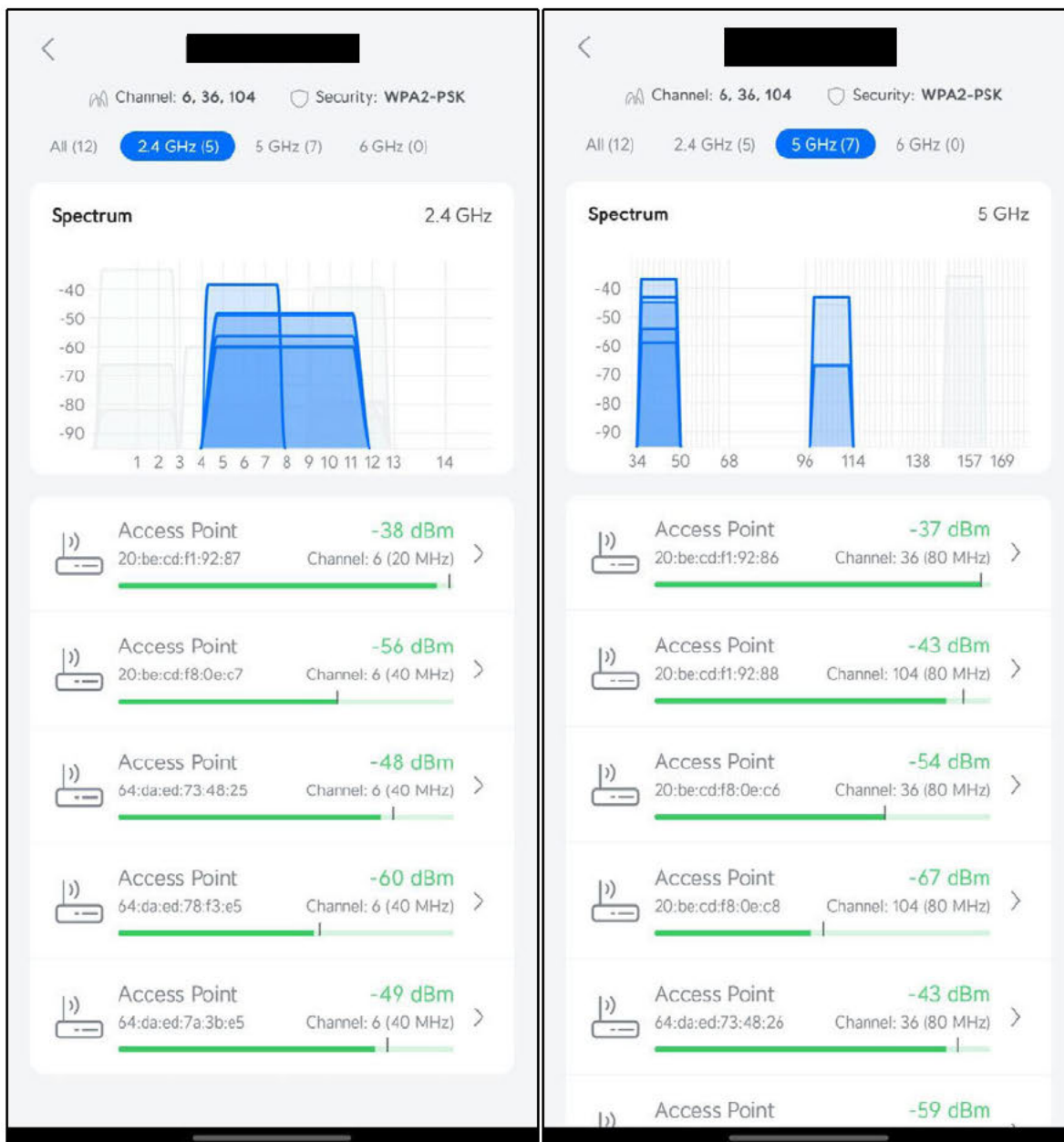
Wi-Fi test result



Eero Wi-Fi kit
Image source: internet

Findings

- The facilities have an Eero Wi-Fi mesh system installed.
- The [REDACTED] Wi-Fi bandwidth is occasionally insufficient, particularly when multiple users connect simultaneously. This issue has been frequently reported by users.
- Wi-Fi on the other floors is adequate and sufficient, with users reporting that the internet works fine.
- It was found that the channels of the Eero mesh Wi-Fi system are overlapping on various floors, which can decrease network performance and lead to increased interference.



Displaying the test results indicating that the Wi-Fi channels are overlapping.

Recommendations

- Verify that the Eero Wi-Fi mesh system on the [redacted] has been correctly installed, and perform a Wi-Fi coverage floor plan scan if necessary to identify any weak spots or areas needing improvement.
- Reconfigure the Wi-Fi channels on the Eero mesh system to reduce overlap and interference, and ensure all access points are set to non-overlapping channels.

Wi-Fi Security Analysis

Home Notify me Domain search Who's been pwned Passwords API About Donate

Pwned Passwords

Pwned Passwords are hundreds of millions of real world passwords previously exposed in data breaches. This exposure makes them unsuitable for ongoing use as they're at much greater risk of being used to take over other accounts. They're searchable online below as well as being downloadable for use in other online systems. [Read more about how HIBP protects the privacy of searched passwords.](#)

..... | pwned?

Oh no — pwned!

→ This password has been seen 102 times before

This password has previously appeared in a data breach and should never be used. If you've ever used it anywhere before, change it!

Source: <https://haveibeenpwned.com/Passwords>

Office Wi-Fi password has been seen 102 times on the internet.

Findings

- The office Wi-Fi is currently using WPA2-PSK for authentication, which is susceptible to being easily cracked by malicious actors.
- The Wi-Fi password in use is weak and has been exposed on the internet 102 times, making it highly vulnerable.
- The last password change was [REDACTED] ago (according to information provided by [REDACTED]), and many individuals now have access to it, increasing the risk of unauthorized access to the office network.

Recommendations

- It is highly recommended to implement WPA3-Enterprise, allowing employees to connect to Wi-Fi using their domain username and password. This is the most secure authentication method currently available.
- If WPA3-Enterprise is not feasible, upgrade to WPA3-PSK.
- Change the Wi-Fi password to one that is at least 8 characters long and meets password complexity requirements.
- Implement a policy to change the Wi-Fi password periodically to reduce the risk of unauthorized access.

Wireless Network Implementation Analysis

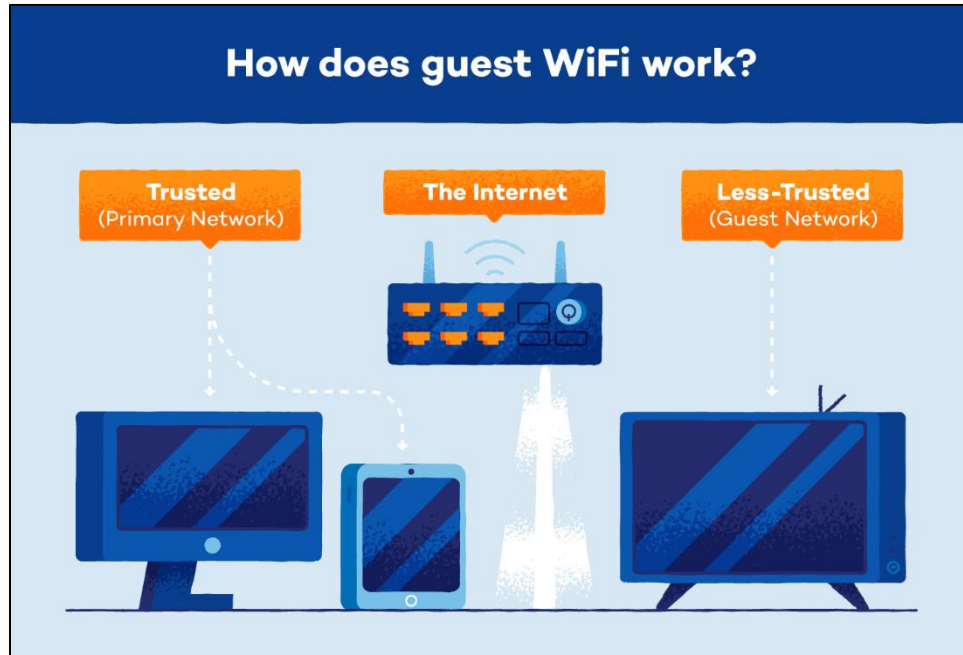


Image source: internet

Findings

- Employees, [REDACTED], and guests are all using the same Wi-Fi network, which poses a significant security risk.
- The facilities are currently using an Eero Wi-Fi mesh system, as previously mentioned.
- Inconsistent Wi-Fi naming conventions were found across the network.

Recommendations

- Implement network segmentation to separate the office network (trusted) from the guest Wi-Fi network (untrusted). This will minimize the impact of guest usage on the office network and enhance security by preventing malware or malicious actors from accessing the office network via the guest Wi-Fi.
- Create a dedicated Wi-Fi network for guests that does not require a password. Guests can connect to this network and use Wi-Fi during a permitted period, after which they will be automatically signed out. Additionally, set bandwidth limitations for the guest Wi-Fi to manage network resources efficiently.
- Standardize Wi-Fi naming conventions to ensure consistency and make network management more streamlined and efficient.
- Consider implementing a centralized managed wireless access point system to improve network management, security, and performance across the facility.

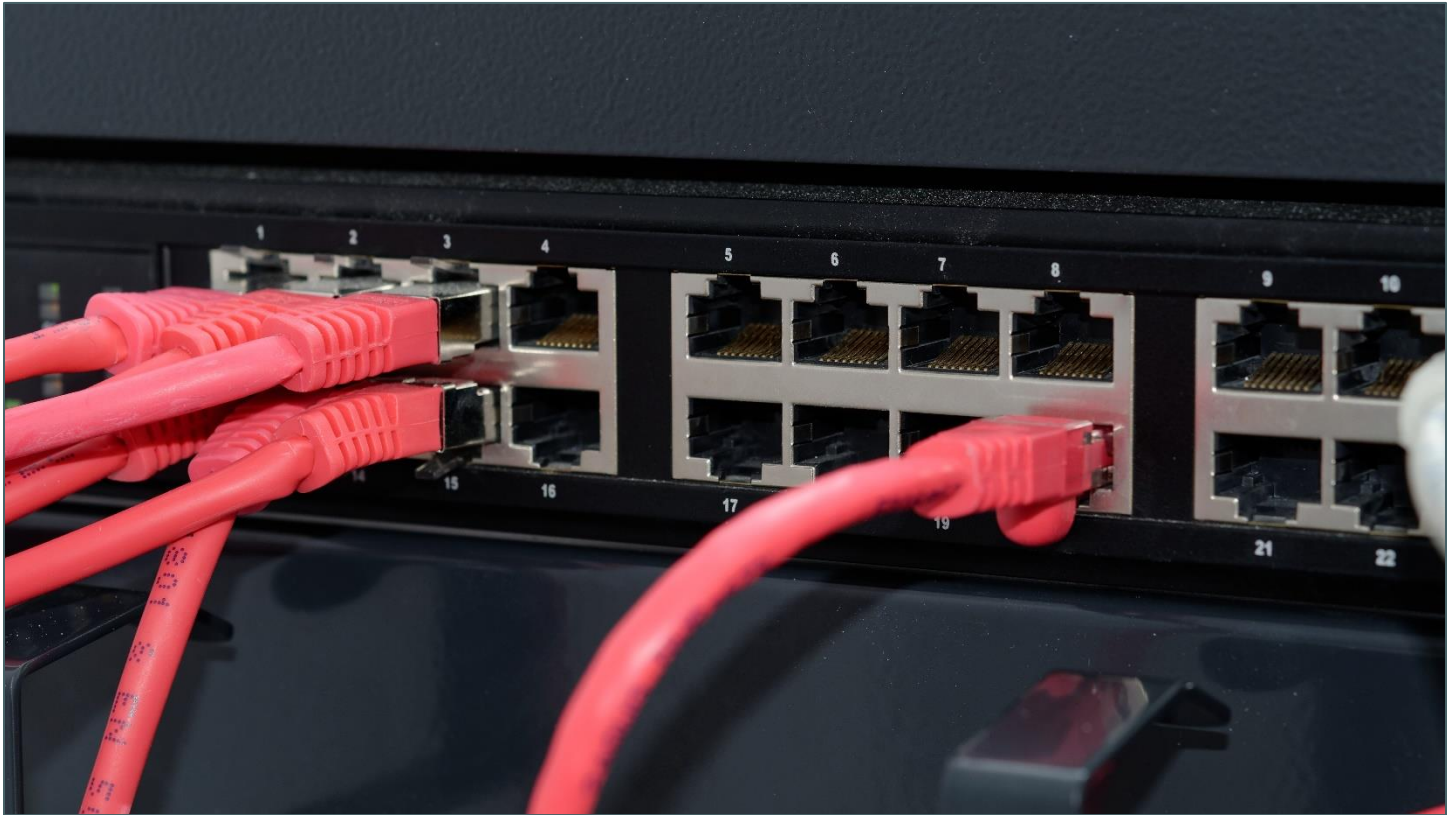
For more information, please refer to the article "**6 Benefits of Using Cloud-Managed Wireless Access Points for Your Business**" at the following link:

<https://www.ray.life/6-benefits-of-using-cloud-managed-wireless-access-points-for-your-business/#:~:text=A%20cloud%2Dmanaged%20access%20point,go%2C%20on%2Ddemand%20model.>

Additionally, consider the recommended **cloud-managed wireless access points** available at:

<https://www.tp-link.com/us/business-networking/ceiling-mount-access-point/eap620-hd/>

Wired Network Implementation Analysis



Ethernet network port implementation
Image source: internet

Findings

- Most users are not utilizing network cables or network ports, relying solely on Wi-Fi.
- Many network ports on various floors are non-functional.

Recommendations

- Enforce the use of network cables among employees, as wired connections offer lower interference and faster speeds compared to Wi-Fi.
- Repair and activate all network ports, as they are essential for connecting computers and office telephone systems.

Internet Outage Analysis

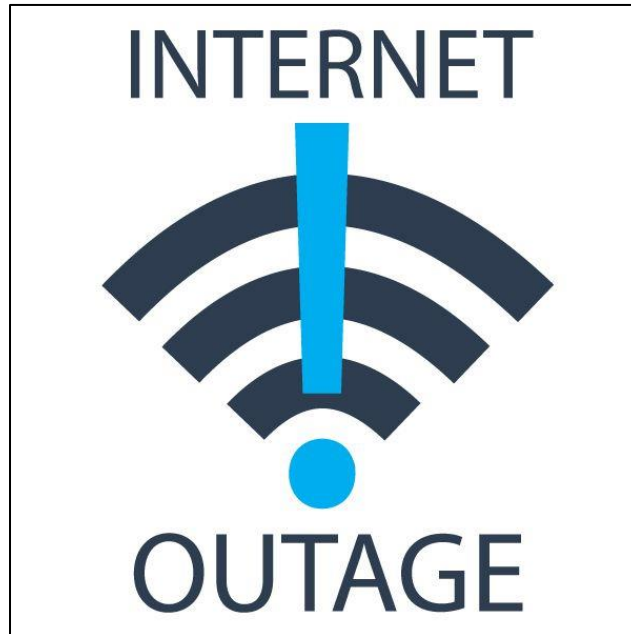


Image source: internet

Findings

- The [REDACTED] Office has experienced internet outages at least three times a year (according to information provided by [REDACTED]). During these outages, employees relied on mobile phone hotspots to access the internet.
- These outages are likely to continue occurring in the future.
- The organization is not utilizing Dedicated Internet Access (DIA), which can result in potential issues such as inconsistent internet performance, limited bandwidth reliability, and reduced control over network traffic. Without DIA, the organization might experience slower speeds during peak times and less guaranteed uptime, which can impact business operations and overall productivity.

Recommendations

- Install a backup internet route to automatically take over if the primary connection goes down. The system should automatically switch back to the primary route once it is restored.
- Negotiate a high SLA (Service Level Agreement) with the internet service provider to ensure a reliable connection and minimize downtime. Ensure the SLA includes strong guarantees for uptime and quick resolution of issues.
- Evaluate and consider the adoption of Dedicated Internet Access (DIA) to ensure consistent and reliable internet performance, enhanced bandwidth, and improved control over network traffic. Implementing DIA can provide the organization with higher speeds, greater reliability, and better support for critical applications and services.

Network Infrastructure Analysis

Findings

- A firewall is not installed, leaving users' web browsing and ad traffic unrestricted. This poses a significant risk, as it can lead to malware infections, ransomware attacks, phishing, and potential compromise by malicious actors.
- The following IP addresses were identified and require further investigation to determine their physical location, status, and configuration:

Gateway router IP address	192 [Redacted]
DHCP server IP address	192 [Redacted]
DNS server IP address	192 [Redacted]

Wireless LAN adapter Wi-Fi:

Connection-specific DNS Suffix . :
Description :
Physical Address. :
DHCP Enabled. :
Autoconfiguration Enabled :
IPv6 Address. :
Temporary IPv6 Address. :
Link-local IPv6 Address :
IPv4 Address. :
Subnet Mask :
Lease Obtained. :
Lease Expires :
Default Gateway :
DHCP Server :
DHCPv6 IAID :
DHCPv6 Client DUID. :
DNS Servers :
NetBIOS over Tcpip. :

[Redacted]

Current network configuration IP addresses

Subnet Mask Report: `255.255.252.0`

Subnet Mask: `255.255.252.0`

CIDR Notation: `/22`

Key Details:

- Total IP Addresses: 1024

- Usable IP Addresses: 1022 (Excludes network and broadcast addresses)

Example:

- Network Address: `192.[Redacted]`

- Broadcast Address: `192.[Redacted]`

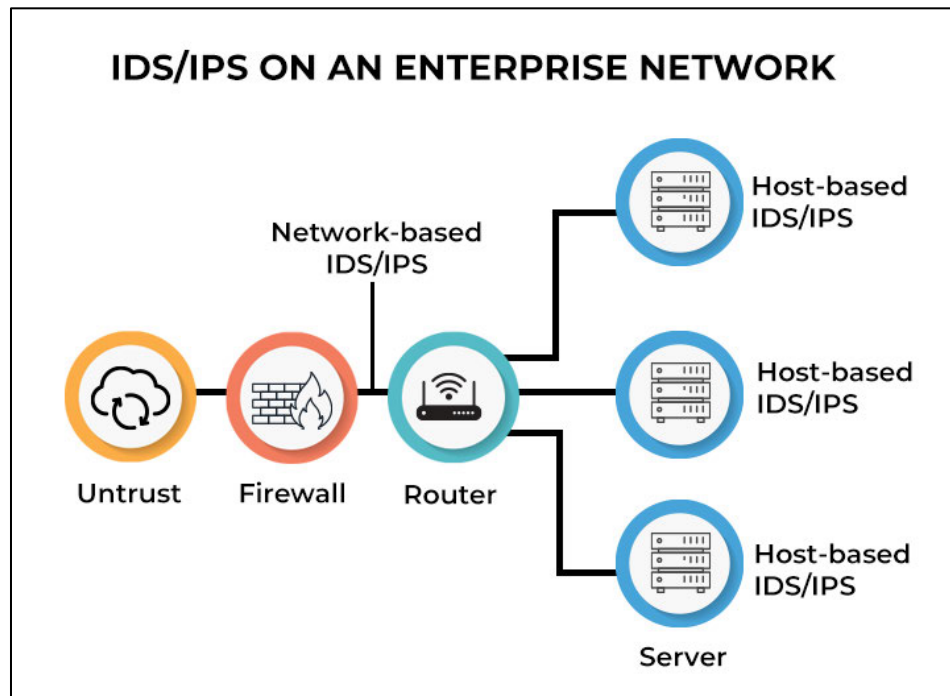
- Usable IP Range: `192.[Redacted]` to `192.[Redacted]`

Conclusion:

The `255.255.252.0` subnet mask provides a large address range, ideal for networks needing up to 1022 hosts. It offers a good balance between network size and address efficiency.

Recommendations

- Install a firewall along with IDS (Intrusion Detection System), IPS (Intrusion Prevention System), EDR (Endpoint Detection and Response), and XDR (Extended Detection and Response) solutions to detect and block unwanted network traffic and malicious content.
- Implement secondary backups for the gateway router, DHCP server, and DNS server to ensure redundancy and minimize downtime in case of failure.



Typical secure office network diagram
Image source: internet

Office Phone System Implementation Analysis



NEC SL2100 phone system installed in [REDACTED]

Findings

- Voicemail is not set up for the office [REDACTED] phone number [REDACTED].
- Some extensions were not installed.
- There is a lack of a consistent floor plan and telephone system design and layout.
- There is no system in place to ensure that if one receptionist cannot answer a call, another can pick it up.
- The organization is currently using a PBX (Private Branch Exchange) phone system for internal and external communications, which may have limitations such as higher maintenance costs, limited scalability, and less flexibility compared to modern VoIP (Voice over Internet Protocol) systems. Additionally, PBX systems can lack advanced features and integrations with other digital communication tools, potentially affecting efficiency and adaptability in a rapidly evolving work environment.

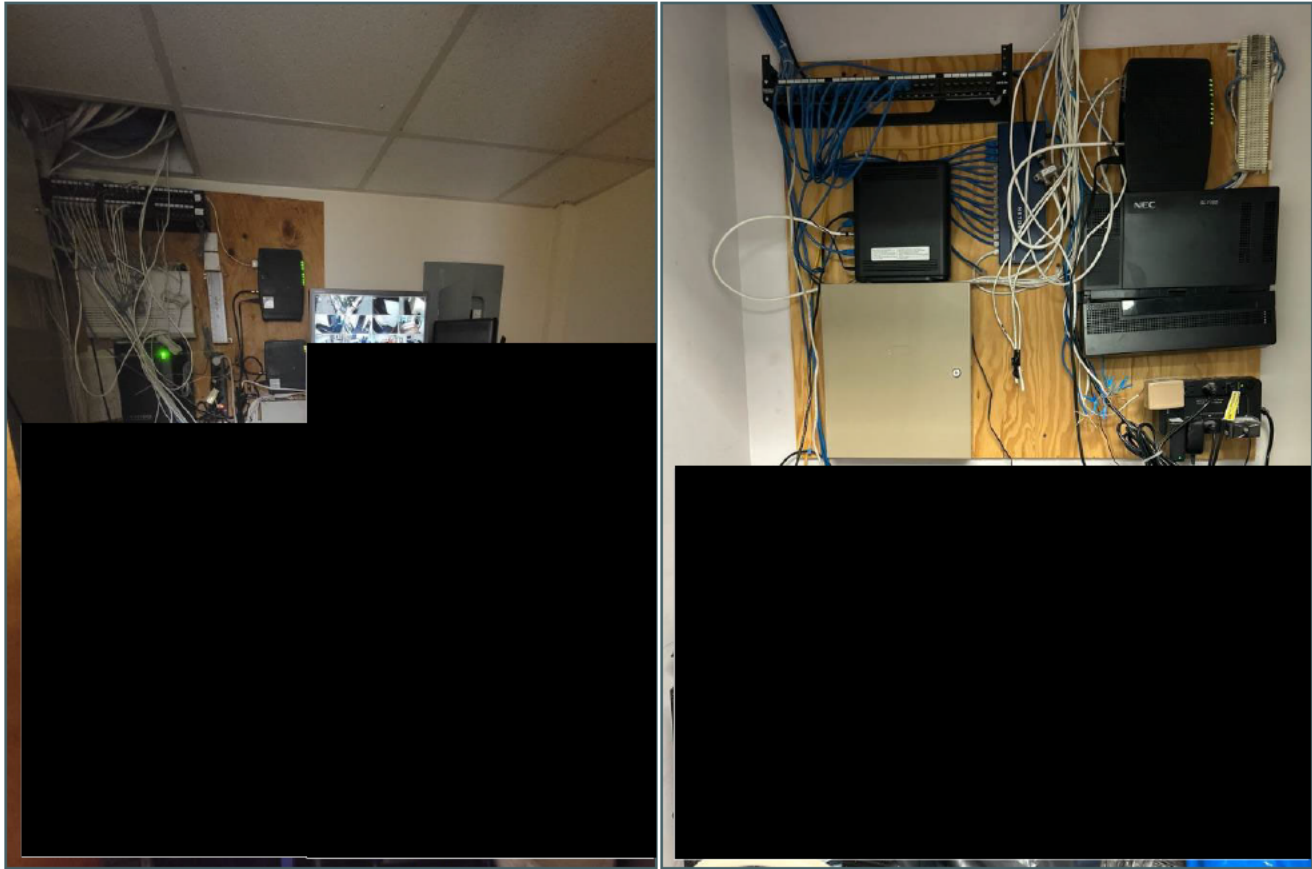
Recommendations

- Set up voicemail for the main operator and all extension numbers.
- Implement a system for receiving text messages.
- Implement an Interactive Voice Response (IVR) system with the following key features:

Key Features of an IVR System:
- Automatic Answering: The system automatically answers incoming calls.
- Voice Prompts: It provides voice prompts, such as asking the caller to enter an extension number or choose from a menu.
- Input Handling: The caller inputs their selection using the keypad or voice commands.
- Call Routing: The system redirects the call to the appropriate extension or department based on the caller's input.

- Implement an operator number (0) for operator-assisted call transfers, allowing employees to reach an operator who will transfer calls to the correct department when the extension is unknown.
- Ensure all network ports in the facility are operational for telephone use.
- Establish a backup system for telephones, especially for the operator.
- Evaluate the current PBX system to ensure it meets the organization's needs and consider transitioning to a modern VoIP (Voice over Internet Protocol) system if it offers enhanced features, scalability, and cost efficiency. VoIP systems can provide advanced functionalities like integration with other communication tools, improved call quality, and better support for remote work.

Networking Devices and Server Locations Analysis



Locations of Networking Devices on the [REDACTED]

Findings

- Networking devices and servers are currently spread across the [REDACTED].
- The devices are not properly maintained, and the cabling is disorganized and poorly arranged.
- No HVAC system is installed in the server rooms.
- The rooms are cluttered with non-IT-related items.
- Proper door locks are not installed, allowing unrestricted access to the devices by anyone in the office.
- There is no proper documentation of changes or upgrades made by technicians.

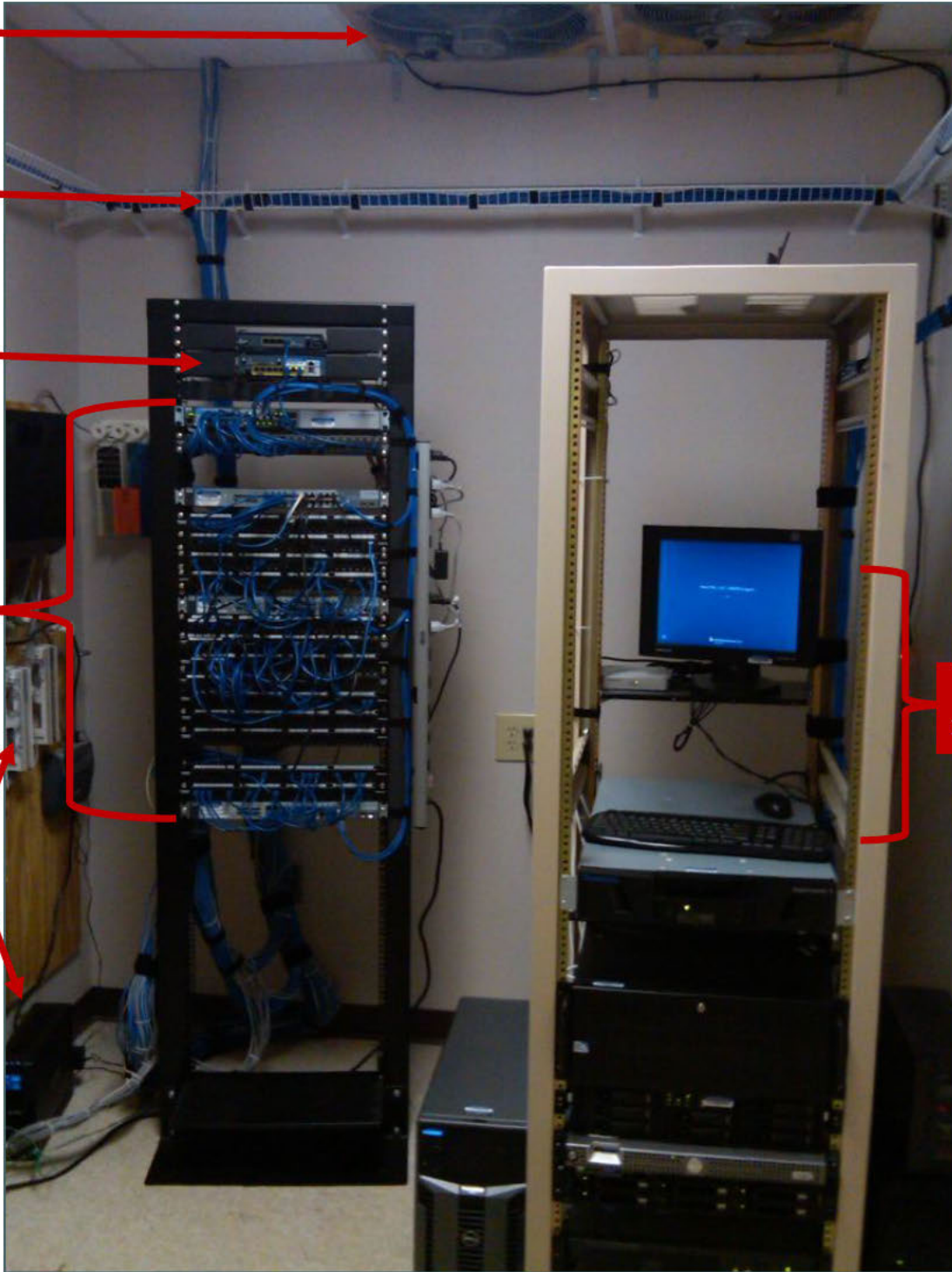
Recommendations

- Centralize the server location on high ground to avoid flooding, ensure no risk of water leakage or electrical outages.
- Restrict access to the server room to authorized personnel only.
- Install an HVAC (Heating, Ventilation, and Air Conditioning) system to ensure optimal temperature and humidity control.
- Implement a comprehensive documentation process for all changes and upgrades made to the network and server infrastructure.
- Ensure the server room is free from non-IT-related items and clutter.

Air ventilator

Cabling

Server rack

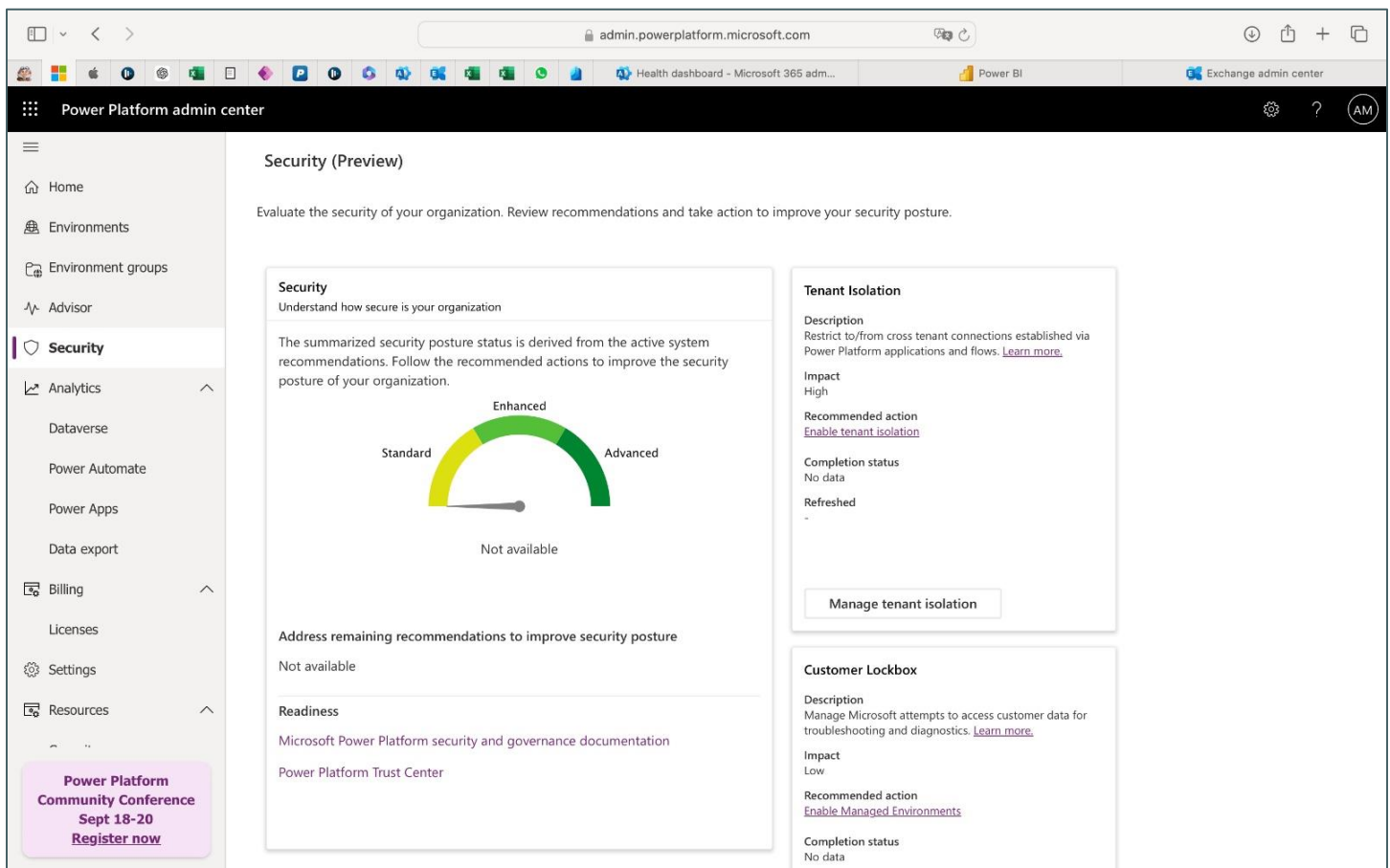
Server and
Networking
devicesElectrical
suppliesServer
management PC

Typical Office Server Room Setup
Image source: internet

Software and Applications Analysis

Findings

- The organization primarily uses web-based applications.
- Most used applications are:
 - Outlook Email
 - Safari or Chrome Browser
 - To access [REDACTED] applications
 - Microsoft Office 365
 - Adobe PDF Reader
 - [REDACTED]
- [REDACTED] applications are developed by a third-party company called [REDACTED] ([https://www.\[REDACTED\].com/](https://www.[REDACTED].com/))
- Tenant-level analytics was turned off.



Tenant-level analytics is turned off.

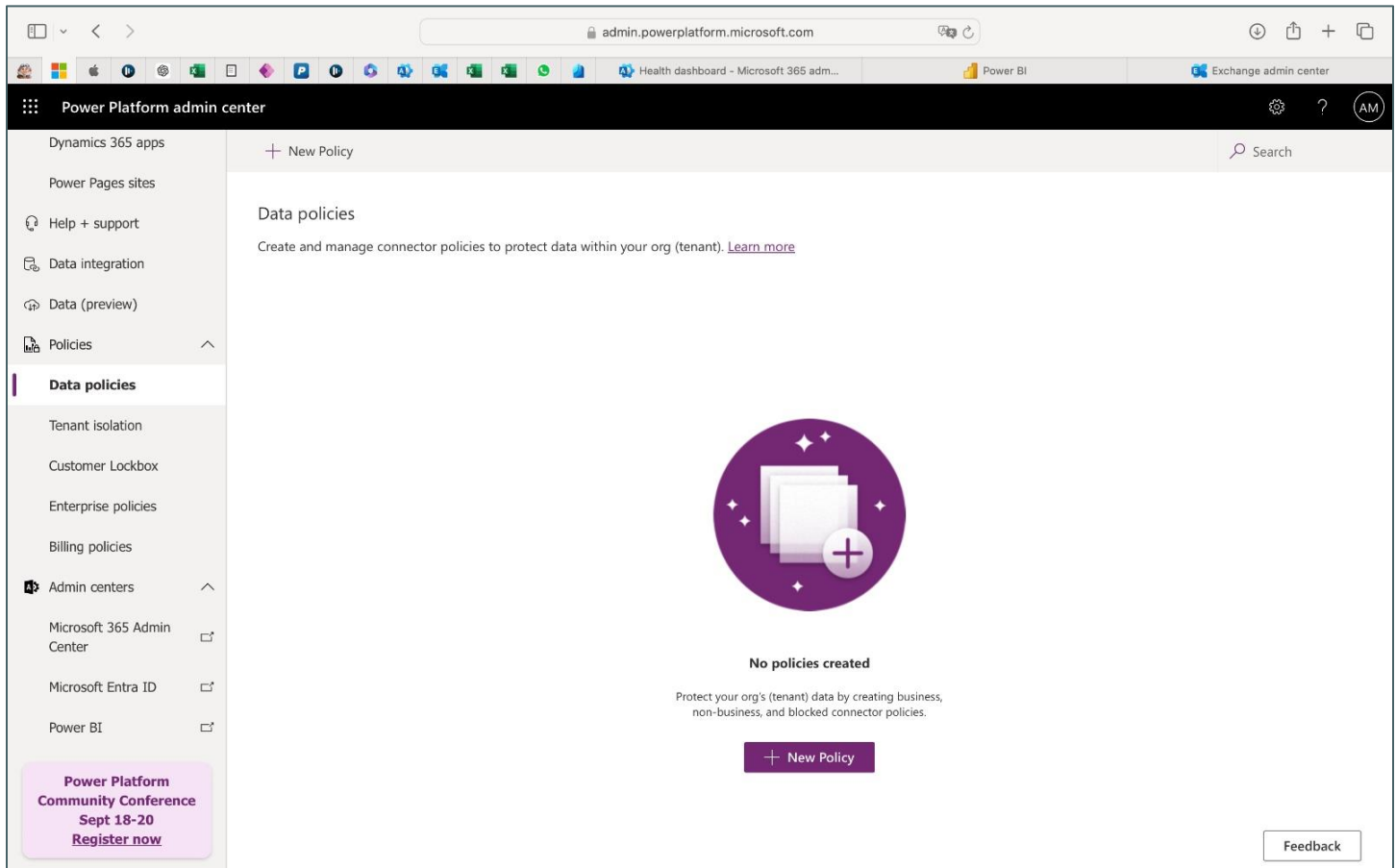
Recommendations

- Consider changing [REDACTED] applications to desktop versions or creating icons to enhance user experience.
- Always enable Tenant-level analytics to assess the organization's security, review recommendations from Microsoft, and take necessary actions to improve security posture.
- Regularly review the security and authentication processes for all applications to ensure they meet current security standards and address any vulnerabilities.

Database and Data Management Analysis

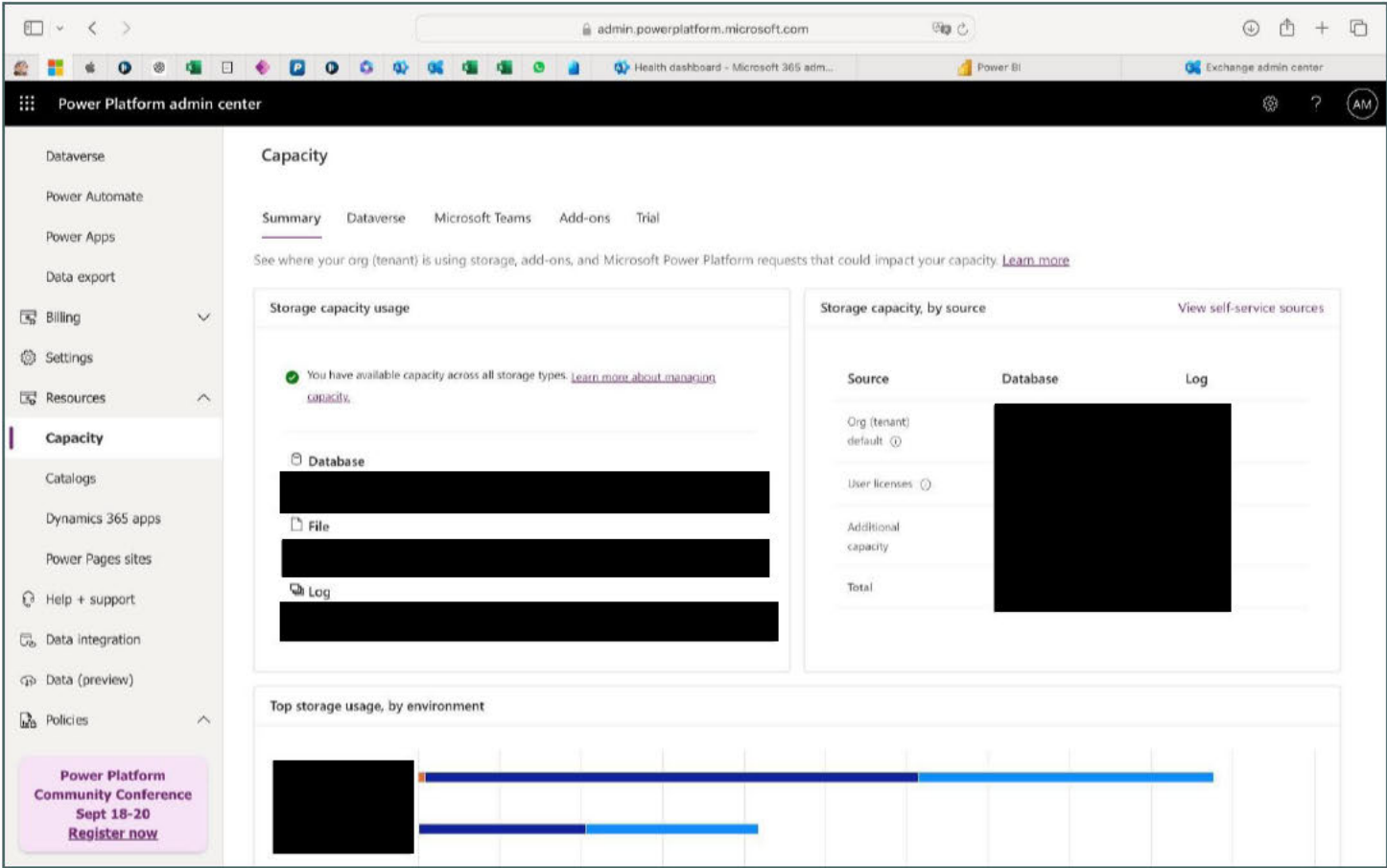
Findings

- [REDACTED] keeps employee records, including Personally Identifiable Information (PII), in physical documents stored in [REDACTED], and electronic copies are stored using a website called [REDACTED] (according to information provided by [REDACTED]).
- File and database backup procedures are unknown and require further investigation.
- No data policies are currently applied to organizational data.



No data policies created

- The current database size is [Redacted] GB, and the file storage size is [Redacted] GB.



Database and File storage sizes

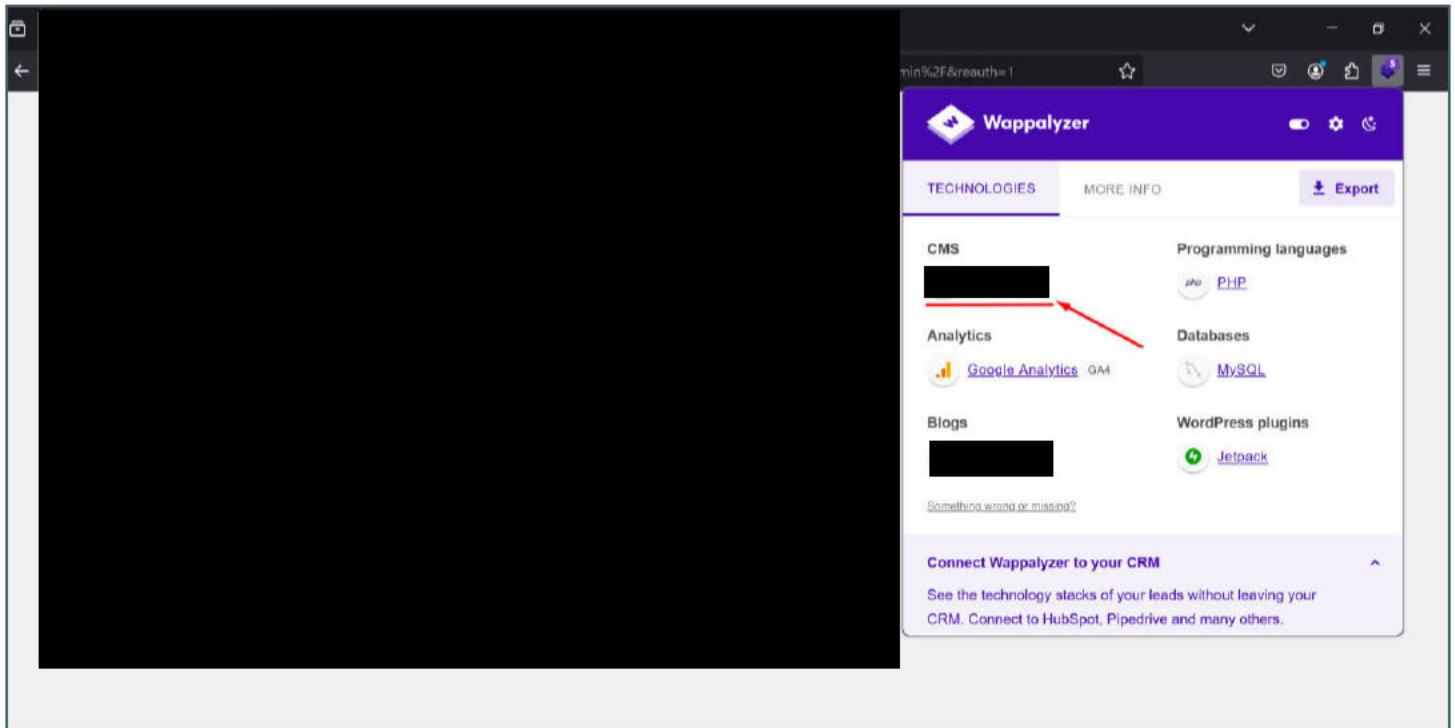
Recommendations

- Implement and enforce data policies to protect organizational data and ensure compliance with relevant regulations.
- Establish and document comprehensive backup procedures for both files and databases to ensure data integrity and availability.
- Review and enhance data management practices to address any gaps and improve overall data security and efficiency.

Website Analysis

Findings

- The organization primarily uses the following websites:
 - [REDACTED].org
 - [REDACTED].org
 - [REDACTED].org
 - [REDACTED].net
 - [REDACTED].org
- These websites are built on the [REDACTED] platform.



[REDACTED] admin login panel and backend technology analysis

Recommendations

- Add more information to the websites and regularly update them with news, stories, blog posts, and the organization's achievements to enhance engagement and attract visitors.
- Consider changing [REDACTED].net to [REDACTED].org to align with the naming convention of other websites.
- Conduct regular security reviews to enhance website security, given that [REDACTED] is more vulnerable to certain types of attacks compared to other website platforms.
- Implement a robust update and patch management process to keep [REDACTED] and all plugins up to date, minimizing potential security risks.

IT Devices Supply Chain and Disposal Analysis

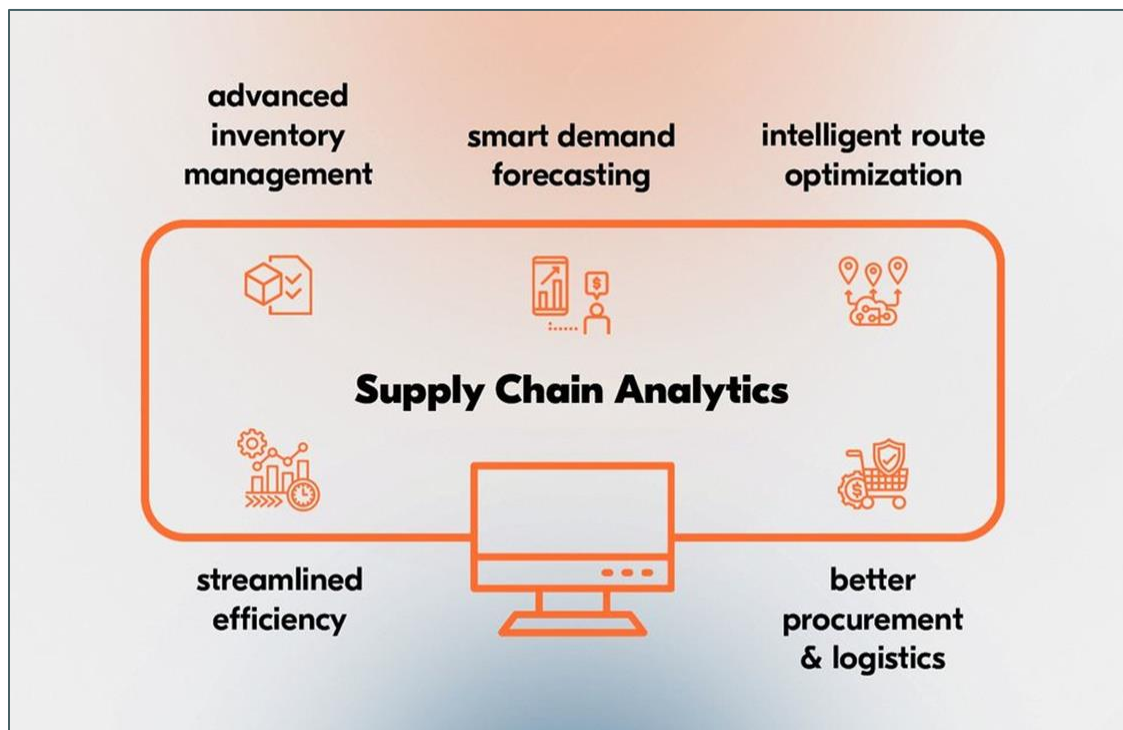


Image source: internet

Findings

- IT equipment is currently ordered from various vendors, including [REDACTED], and others (according to information provided by [REDACTED]).
- Further investigation is needed to fully understand the organization IT equipment supply chain, vendor support, and warranty information.
- There is a need for further investigation to gain a deeper understanding of how the organization disposes of IT equipment and devices.

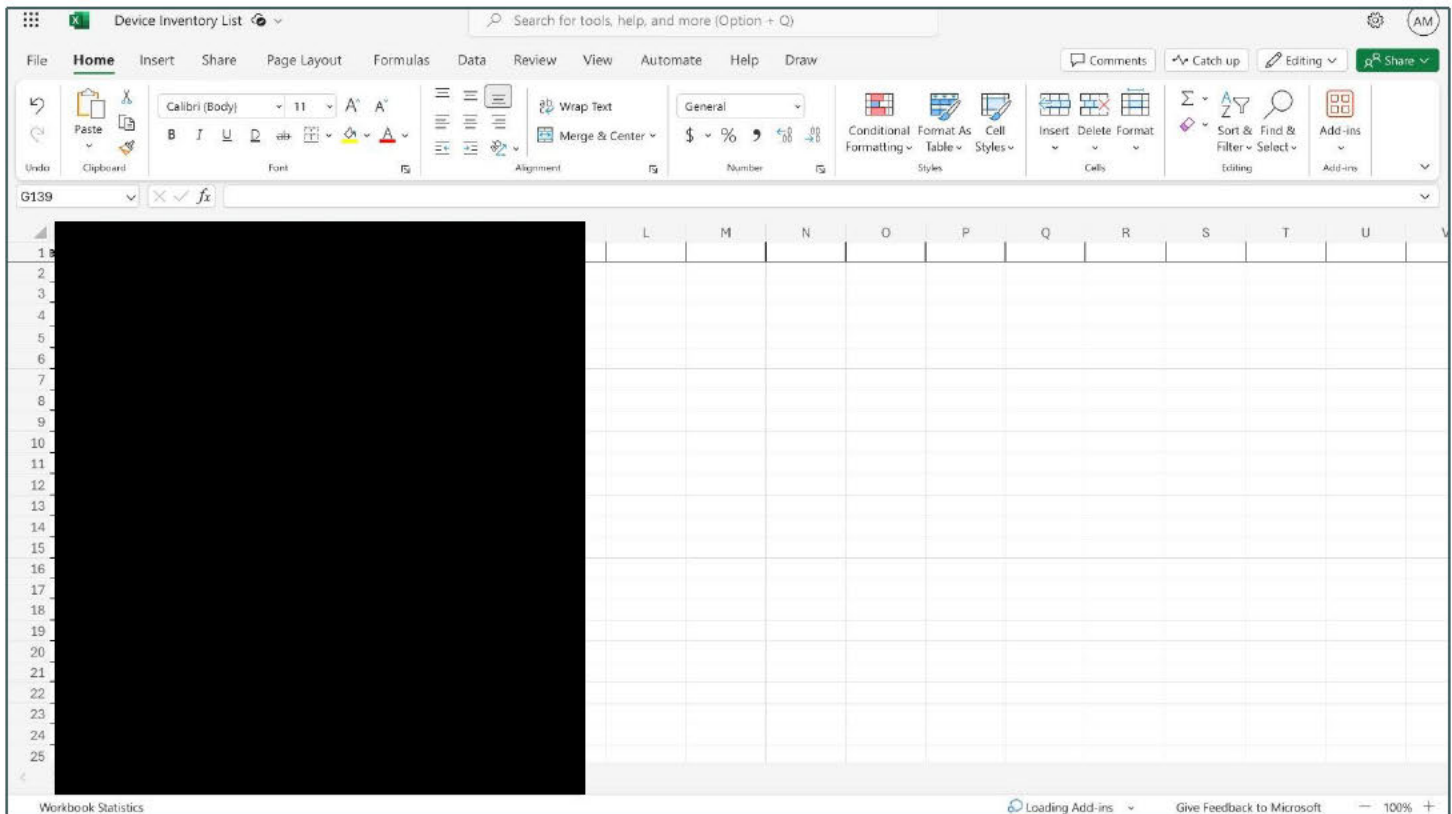
Recommendations

- Purchase equipment from authorized stores to avoid counterfeit parts and ensure product authenticity.
- Consolidate purchases with a select group of trusted vendors to streamline procurement and improve vendor relationships.
- Ensure that all IT equipment comes with comprehensive warranty and support agreements to minimize downtime and maintenance costs.
- Regularly review vendor performance and support to ensure they meet the organization's needs and standards.
- Implement a forecasting model to predict future IT equipment needs based on historical usage data, upcoming projects, and expected growth.
- Conduct a comprehensive review of current IT equipment and device disposal processes to ensure that sensitive data is securely erased and that disposal methods comply with industry standards and regulations. Implement regular audits and training to reinforce these practices.

IT Inventory and Storage Analysis

Findings

- The IT department's inventory sheet is incomplete and not up to date.



Current inventory sheet

- The storage area lacks some spare IT devices, peripherals, and other essential equipment. Further investigation is required.
- The current storage location is temporary (according to information provided by [REDACTED]).
- The installed IT devices do not have a naming convention.

Recommendations

- Conduct a thorough audit of all IT equipment and update the inventory sheet to ensure accuracy.
- Establish a permanent, secure storage location for IT devices and peripherals.
- Maintain an adequate supply of spare IT devices and peripherals to minimize downtime in case of equipment failure.
- Create and implement a consistent naming convention for every IT device in the office to improve asset tracking and management.
- Implement a regular inventory management process to keep the inventory sheet up to date, including detailed information on IT assets such as make, model, serial number, purchase order, tag number (if any), and device name.

Analysis of Frequently Reported User Issues and Ticketing System Performance in Recent Years



Overview of Ticket Resolution in 2023



Overview of Ticket Resolution in 2024

Findings:

- The average ticket completion time last year was 7 days; this year, it has improved slightly to 6 days.
- Users predominantly report issues related to Wi-Fi connectivity, device assistance (mainly software and configuration settings), and printer cartridge replacement.
- It was found that some users are unaware of how to submit tickets for IT support, and some prefer to directly contact IT personnel instead of using the ticketing system.
- The [REDACTED] ticketing system lacks essential user directory features, such as details on users' roles, managers, departments, and locations. For example, if support staff do not have information on a user's location, they may struggle to determine if the issue is specific to a particular office or geographic area. This can lead to delays in addressing location-specific problems, such as regional network outages or hardware malfunctions. Consequently, support staff might inadvertently provide generalized solutions that don't address the root cause of the issue, leading to unresolved problems and extended downtime for affected users.
- Users often bypass the ticketing system by calling support staff directly instead of submitting tickets, which can lead to challenges in tracking, prioritizing, and resolving issues. This practice can result in inefficient support operations, delays in issue resolution, and difficulties in maintaining comprehensive records of support activities.

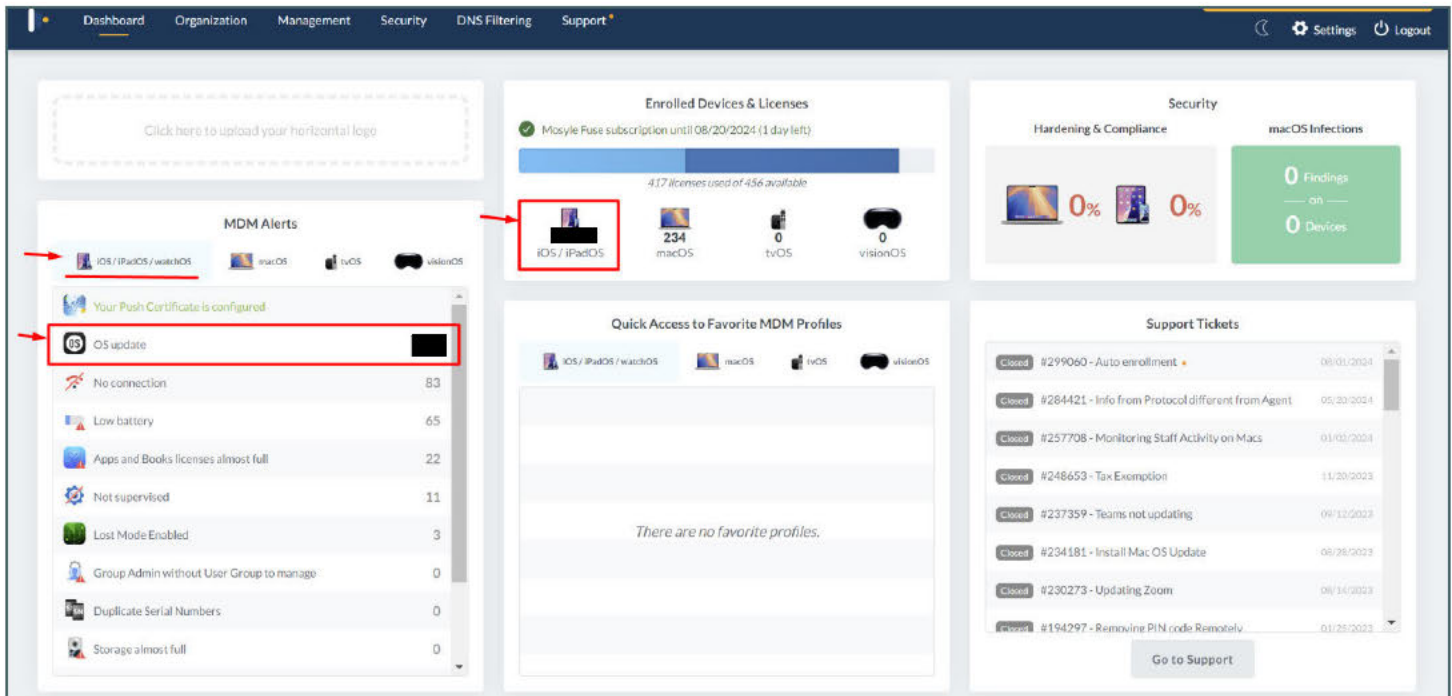
Recommendations:

- The average resolution time needs improvement; aim to reduce it to 3 to 4 days for optimal efficiency.
- Focus on addressing recurring issues permanently, particularly those frequently reported by users.
- Enforce the use of the ticketing system by all users, as it streamlines follow-ups and ensures that all requests are tracked and addressed efficiently.
- Integrate [REDACTED] with Microsoft Entra ID to automatically synchronize the user directory, including details such as roles, managers, departments, and locations. This integration will provide support staff with the necessary user information, reducing response times and improving service accuracy. Additionally, consider evaluating and potentially adopting [REDACTED] as an alternative ticketing system due to its extensive feature set and broader adoption in IT companies, which may better meet the organization's needs. For more information, visit [https://www.\[REDACTED\].com/](https://www.[REDACTED].com/).
- Enforce the use of the ticketing system by informing users that they can easily submit tickets from their PC or mobile phone. Implement mandatory policies for ticket submission and provide training to ensure all support requests are properly logged, tracked, and managed through the ticketing system.

Centralized Device Management Analysis

Findings

- The organization primarily uses [REDACTED] devices, including all PCs, laptops, and mobile phones, managed through [REDACTED]. However, several issues were identified:
 - A significant number of devices have outdated operating systems.
 - None of security rules are activated across the organization's devices.
 - Outdated Antimalware Definitions were found.
 - The organization has not deployed DNS filtering, nor established allowed and blocked domain lists.



[REDACTED] out of [REDACTED] iOS (mobile) devices require OS (Operating System) update

Click here to upload your horizontal logo

MDM Alerts

Your Push Certificate is configured

OS update

No connection 99

Duplicate Serial Numbers 2

Apps and Books licenses almost full 2

MDM Approval required 0

Group Admin without User Group to manage 0

Storage almost full 0

MDM profile removed 0

Enrolled Devices & Licenses

Mosyle Fuse subscription until 08/20/2024 (1 day left)

417 licenses used of 456 available

183 iOS / iPadOS / watchOS

0 macOS

0 tvOS

0 visionOS

Quick Access to Favorite MDM Profiles

There are no favorite profiles.

Security

Hardening & Compliance 0%

macOS Infections 0 Findings 0 Devices

Support Tickets

Closed #299060 - Au to enrollment 09/01/2024

Closed #284421 - Info from Protocol different from Agent 05/20/2024

Closed #257708 - Monitoring Staff Activity on Macs 01/02/2024

Closed #248653 - Tax Exemption 11/20/2023

Closed #237359 - Teams not updating 09/12/2023

Closed #234181 - Install Mac OS Update 08/26/2023

Closed #230273 - Updating Zoom 08/14/2023

Closed #194297 - Removing PIN code Remotely 01/25/2023

Go to Support

out of macOS (PCs, laptops) devices require OS (Operating System) update

Manage macOS

macOS

Mac Security Overview

Hardening & Compliance

Overview

Active Rules

Devices

Logs

Detection & Removal 2

Admin On-Demand

Automated Zero Trust Beta

Welcome to Security Compliance for macOS

With the new Security Compliance for macOS, you now can constantly check your macOS devices for critical security controls for ensuring the sophisticated security protections that are part of macOS are running and configured correctly.

Security Compliance also allows you to automatically fix any misconfiguration identified so your devices will always be in compliance and protected, while you don't have to take any specific action for that.

Mosyle brings a large number of controls that are part of important security benchmarks as CIS macOS and NIST 800-53. Mosyle also maps controls against expected requirements for SOC2 Certification.

With Mosyle Security Compliance you can also create customized security controls to check your devices against. Your customized controls will generate a Security Group for the devices not in compliance and any Mosyle profile can be assigned to such group, allowing you easily create a fully automated cycle of identifying and fixing your custom security controls.

Finally, Security Compliance will provide you with detailed reports that will have all the necessary information internal and external audits, saving immense time for you when showing the security compliance of your macOS devices.

Use the options at the right to start now.

Activate the rules for checking in Bulk based on benchmark now.

Mosyle Basic Selection (66 rules)

☒ CIS Level 1 (73 rules)

☐ CIS Level 2 (10 rules)

☐ NIST (78 rules)

☐ PCI 4.0 (97 rules)

☐ SOC 2 (92 rules)

Rule Assignment

Select what users and devices will receive this rule.

No users or devices assigned.

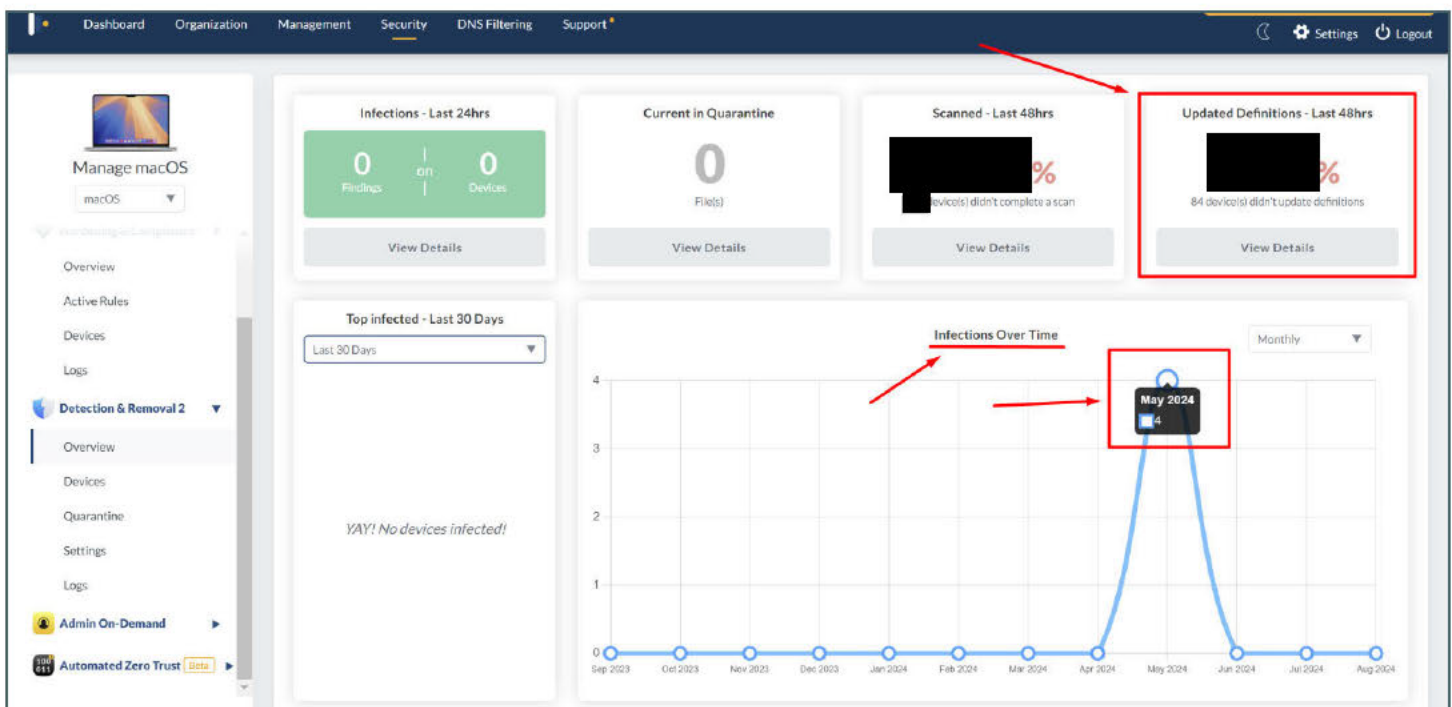
+ Add Assignment

Start

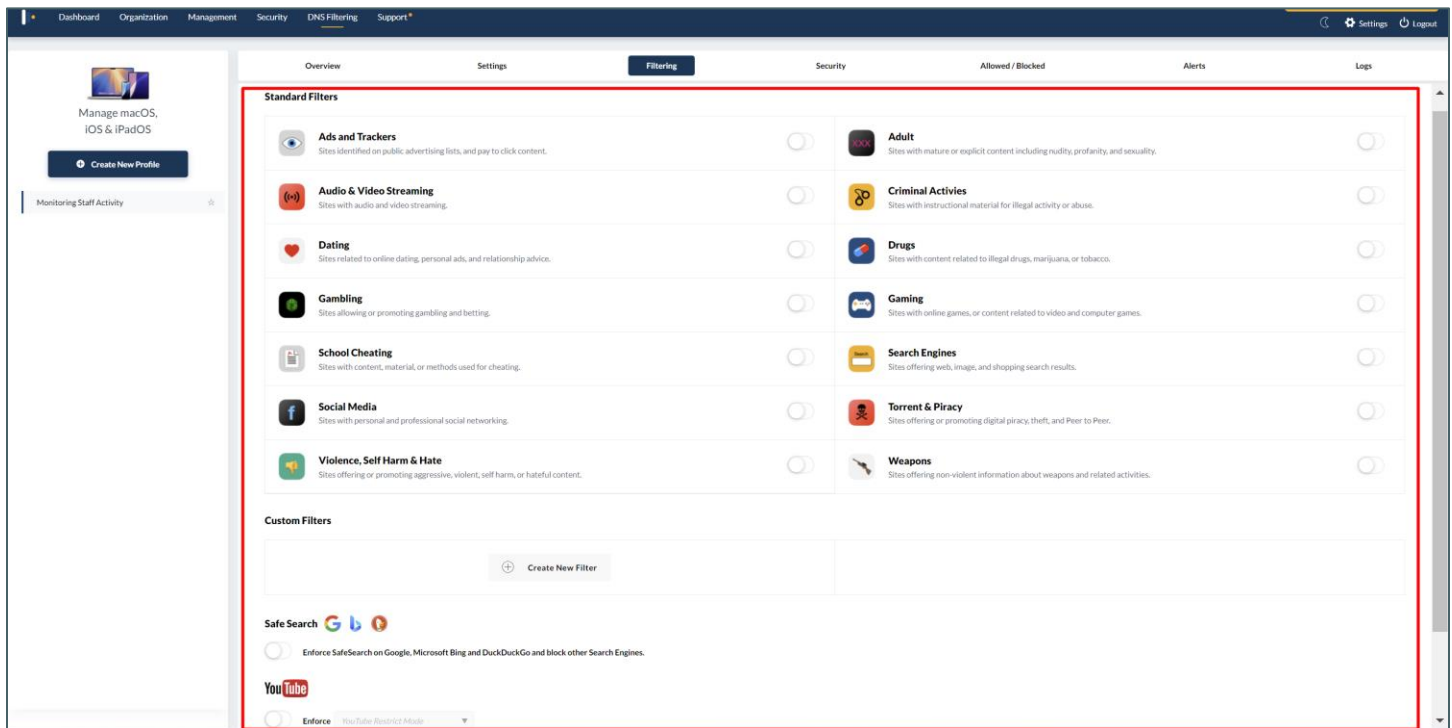
allows security rules based on standards: CIS, NIST, PCI, and SOC2

The screenshot shows the 'Security' dashboard with a sidebar on the left containing 'Manage macOS', 'Mac Security Overview', 'Hardening & Compliance', 'Detection & Removal 2', 'Admin On-Demand', and 'Automated Zero Trust'. The main area has a search bar, a filter dropdown, and buttons for 'Bulk Assignment' and 'Bulk Remove'. A message 'No Rules found.' is displayed in the center, with a red arrow pointing to it.

No security rules have been activated across the organization's devices

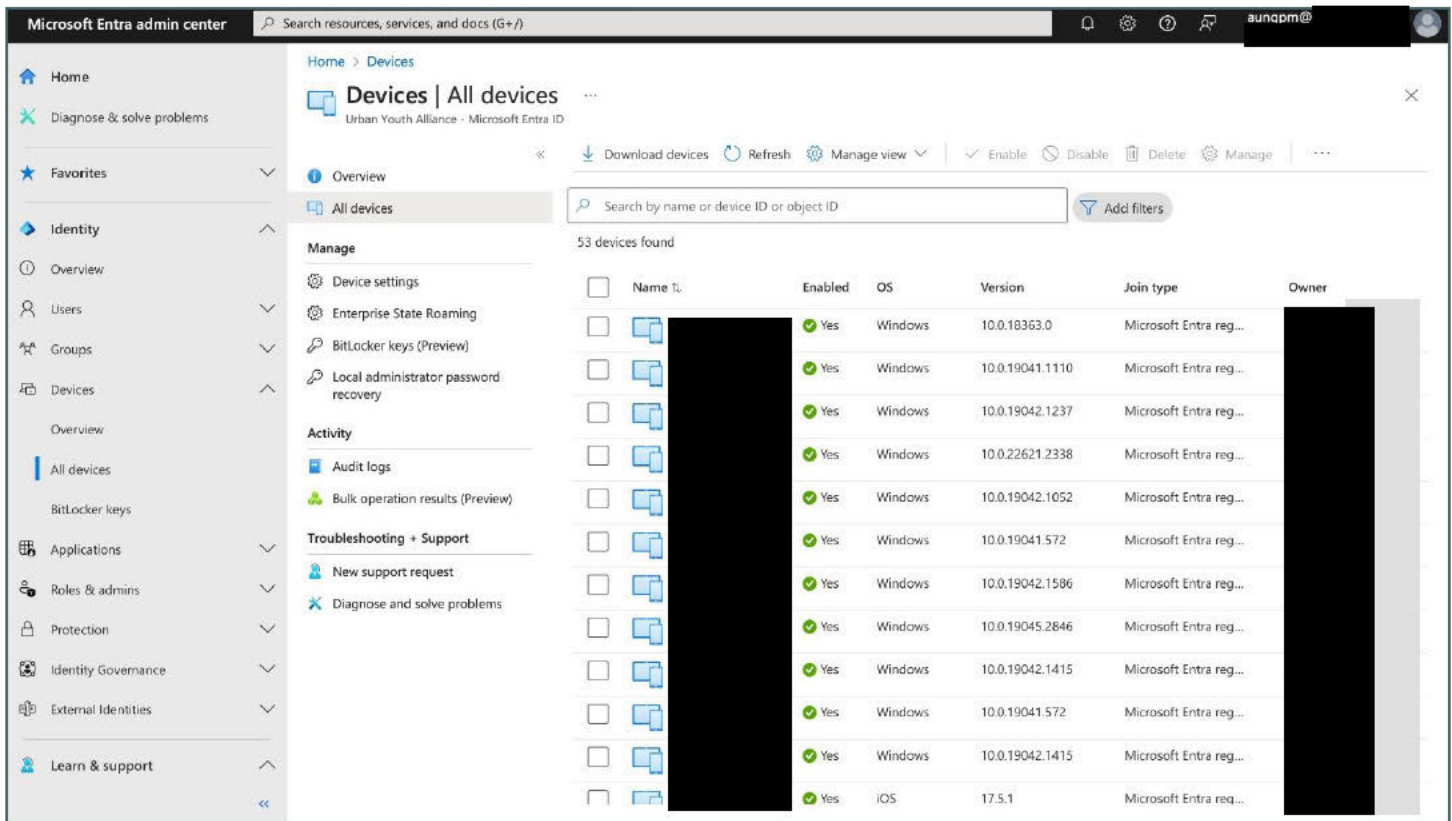


Only █████% of devices receive updated antimalware definitions, leaving █████ devices without recent updates
██████ devices were infected in May 2024



DNS Filtering Not Deployed: No Allowed or Blocked Domains Configured

- Users rely on individual iCloud and OneDrive storage accounts with no centralized shared drives in place.
- Microsoft accounts are used for SSO (Single Sign-On) on some platforms, but the feature is not widely adopted.
- While basic email lookup works in Outlook, advanced email lookup is not installed, and no centralized phone book is available on mobile devices.
- Although Microsoft Entra ID is set up in the cloud, it is not being used effectively.



Microsoft Entra ID administrator portal

- There is no enterprise-wide third-party security endpoint protection; only a few devices have [REDACTED] security software installed (according to information provided by [REDACTED]).
- No encryption solution is in place, posing a significant risk if devices are stolen. Without encryption, sensitive data stored on these devices remains accessible to unauthorized individuals, potentially leading to data breaches and security vulnerabilities.
- There is no printer management solution in place. Printers are connected wirelessly without proper naming conventions and secure printing features.

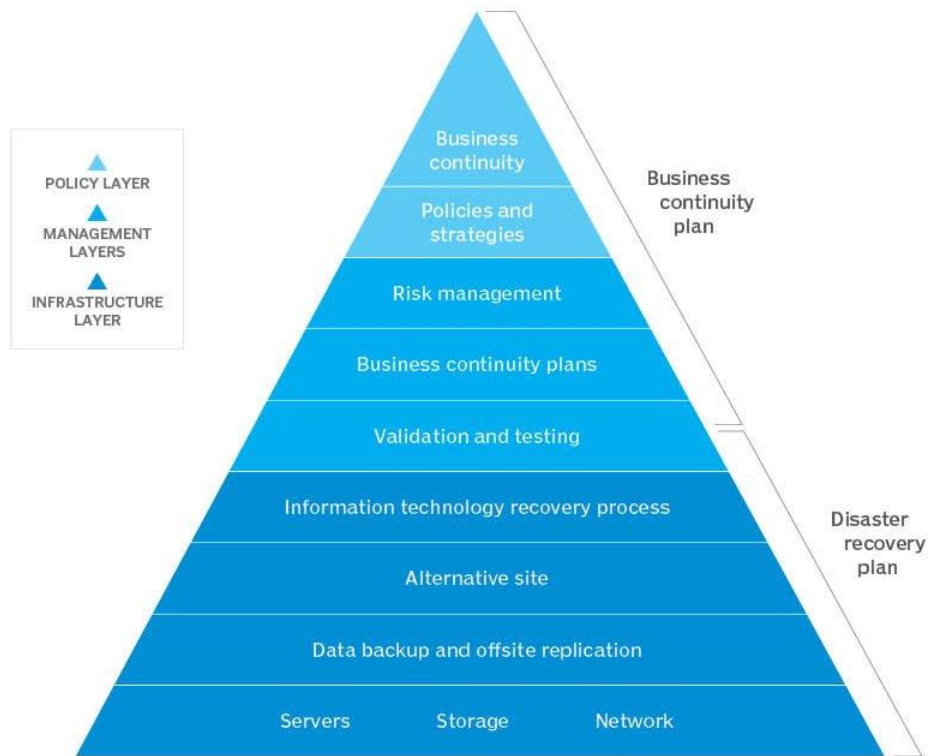
Recommendations

- Update all devices to the latest operating system versions to ensure security patches and performance improvements are applied. Implement a regular update schedule to keep operating systems current and minimize vulnerabilities.
- Utilize [REDACTED]'s security standards (CIS, NIST, PCI, SOC2) to protect devices across the organization.
- Implement DNS filtering and establish lists of allowed and blocked domains to improve network security by preventing access to malicious sites and controlling web traffic.
- Ensure that all devices receive timely antimalware definition updates by implementing automated update policies. Monitor and verify that 100% of devices are up-to-date to reduce the risk of malware infections. Consider investing in more robust antimalware solutions with better coverage and regular update mechanisms.
- To prevent ransomware and malware attacks, adopt a robust security product like [REDACTED] [https://www.\[REDACTED\].com/](https://www.[REDACTED].com/), which offers both antimalware and encryption capabilities.
- Provide centralized storage solutions for departments to enhance collaboration and data management.
- Expand the adoption of Single Sign-On (SSO) across all platforms to enhance security, simplify user authentication, and improve user experience by providing a seamless and consistent login process.

- Introduce a printer management solution, assign names to printers, implement secure print features (e.g., tap badge), and connect printers via wired connections for reliability.
 - Tap badge secure print involves requiring users to authenticate at the printer using a badge or card before their print job is released. This process ensures that only the authorized user who sent the print job can access it, reducing the risk of sensitive documents being left unattended or accessed by unauthorized individuals. This approach also helps in tracking and managing print usage more effectively.
- Deploy encryption software on all devices to safeguard data in case of theft.
- Install advanced email lookup in Outlook and implement a centralized phone book on mobile devices.
- Encourage effective use of Microsoft Entra ID for better identity management.

Business Continuity and Disaster Recovery (BC/DR) Analysis

Business continuity and disaster recovery planning



SOURCE: EZE CASTLE INTEGRATION

©2022 TECHTARGET. ALL RIGHTS RESERVED. TechTarget

Image source: internet

DIFFERENCES BETWEEN BUSINESS CONTINUITY AND DISASTER RECOVERY

Key issue	Business continuity	Disaster recovery
Organizational priorities	Ensuring that the business can remain operational during a crisis and trying to keep disruptions to a minimum	Attempting to limit system failures and restoring systems as quickly as possible
Scope of actions	Includes all of the necessary business functions that help to keep the organization running	Generally focuses on single IT systems and the storage of data
When to commence	When decision makers learn about a critical situation	A post-incident response that will commence after the initial business continuity stages
When to conclude	When business returns to normal at the conclusion of the disaster	When IT systems and infrastructure are returned to their pre-disaster state
Analysis of risk	As part of business continuity planning, an analysis should be made of all potential risks that have a realistic chance of negatively affecting business operations	Disaster recovery planning involves making assessments about potential risks and threats to IT systems and data

alert-software.com

Image source: internet

Findings

- There is no Business Continuity Assessment (BCA), Disaster Recovery Plan (DRP), or incident response plan in place.
- There is no table-top exercise conducted to simulate responses to impacts, downtime, or outages.

Recommendations

- Develop and implement a comprehensive Business Continuity Assessment (BCA), Disaster Recovery Plan (DRP), and incident response plan, ensuring inclusion of details on location, backup sites, weather conditions, communication plans, roles and responsibilities, data recovery procedures, testing and drills, resource management, and regulatory compliance to enhance preparedness and resilience.
- Establish and define the intended Recovery Time Objective (RTO) and Recovery Point Objective (RPO) to ensure that the organization can recover effectively from disruptions and minimize data loss.
- Implement regular table-top exercises to simulate various scenarios of impact, downtime, or outages. This will help ensure that staff are prepared to handle emergencies effectively and that the organization's response plans are tested and refined.

IT Department Standards and Policies Analysis

Findings:

- There are no established standards, policies, or procedures in place for the IT department.
- There is no acceptable use policy currently implemented.

Recommendations:

- Develop and implement standardized policies and procedures for the IT department based on industry standards and frameworks such as NIST (National Institute of Standards and Technology), ISO (International Organization for Standardization), and other relevant standards to ensure consistency, compliance and efficiency in operations.
- Establish an acceptable use policy to outline guidelines and expectations for the appropriate use of IT resources and assets.

NIST CSF vs ISO 27001 Differences	
NIST CSF	ISO 27001
NIST is designed for federal agencies and organisations that work with federal agencies	ISO 27001 is for any international organization looking to maintain a strong ISMS
NIST CSF has various control catalogues	ISO 27001 has Annex A that provides 14 control categories
NIST CSF framework focuses on the three core components: The core, Implementation tiers, Profiles	ISO 27001 is less technical when compared to NIST CSF. It lists the globally accepted best practices required.
NIST does not depend on audits and certifications	ISO 27001 mandates independent audits and certifications
NIST has five functions that organisations can lean on to customize the framework to their business	ISO 27001 has ten standard clauses for organisations to build and improve their ISMS
NIST is free	ISO 27001 charges a fee for users to access its data

Image source: internet

Physical and Perimeter Security Analysis

Findings

- The organization currently uses [REDACTED]
- CCTV systems are distributed across various floors.
- “Crime prevention through environmental design” is in place, with office doors and walls being visible through glass.
- Employees are not consistently wearing badges.



Crime prevention through environmental design
Image source: internet

Recommendations

- Install a door access control system that includes the following features:
 - A one-time purchase model without ongoing subscription fees.
 - A web-based user interface (WebUI) that allows the organization to manage access permissions and make changes independently, without needing to contact the manufacturer.
 - Logging capabilities to record who accesses doors and at what times.
 - Configurable time slots for entry permissions, allowing different access levels based on time (e.g., managers can access at any time while lower-level employees have restricted hours).
 - Flexibility to use cards from various manufacturers without being tied to a single supplier.
 - For more information: Please read this article for a brief explanation of badge access control systems: <https://getsafeandsound.com/blog/badge-access-control-systems/>
- Centralize CCTV system monitoring and regularly audit CCTV system (storage, backup, security).
- Continue to promote and enhance “Crime prevention through environmental design”.

- Implement a strict badge policy to ensure employees consistently wear their identification badges while on premises. This will enhance security by ensuring that only authorized personnel are allowed access to secure areas, facilitate easy identification of employees, and prevent unauthorized access.



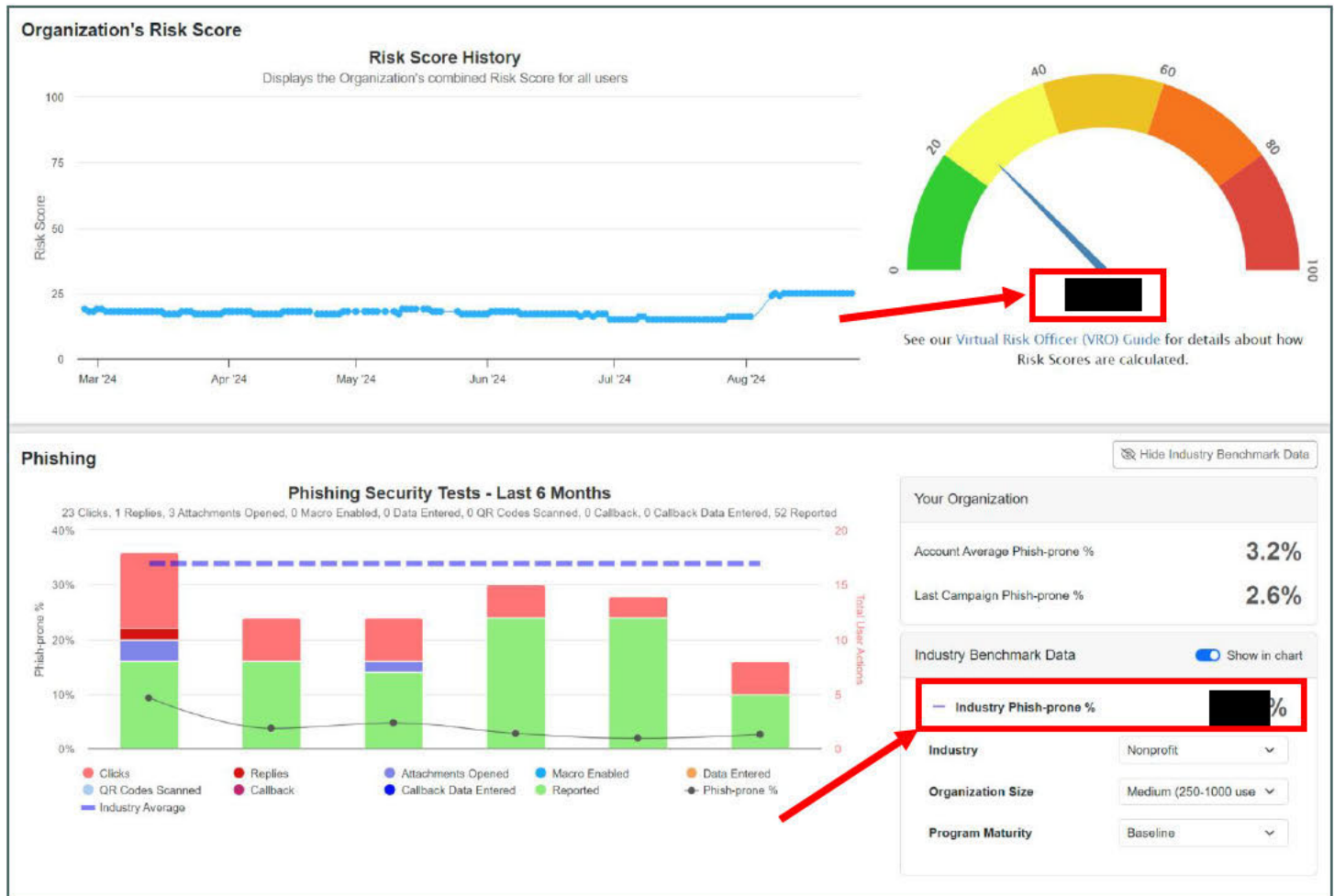
Badge Access Control System

Image source: internet

Security Awareness Analysis

Findings

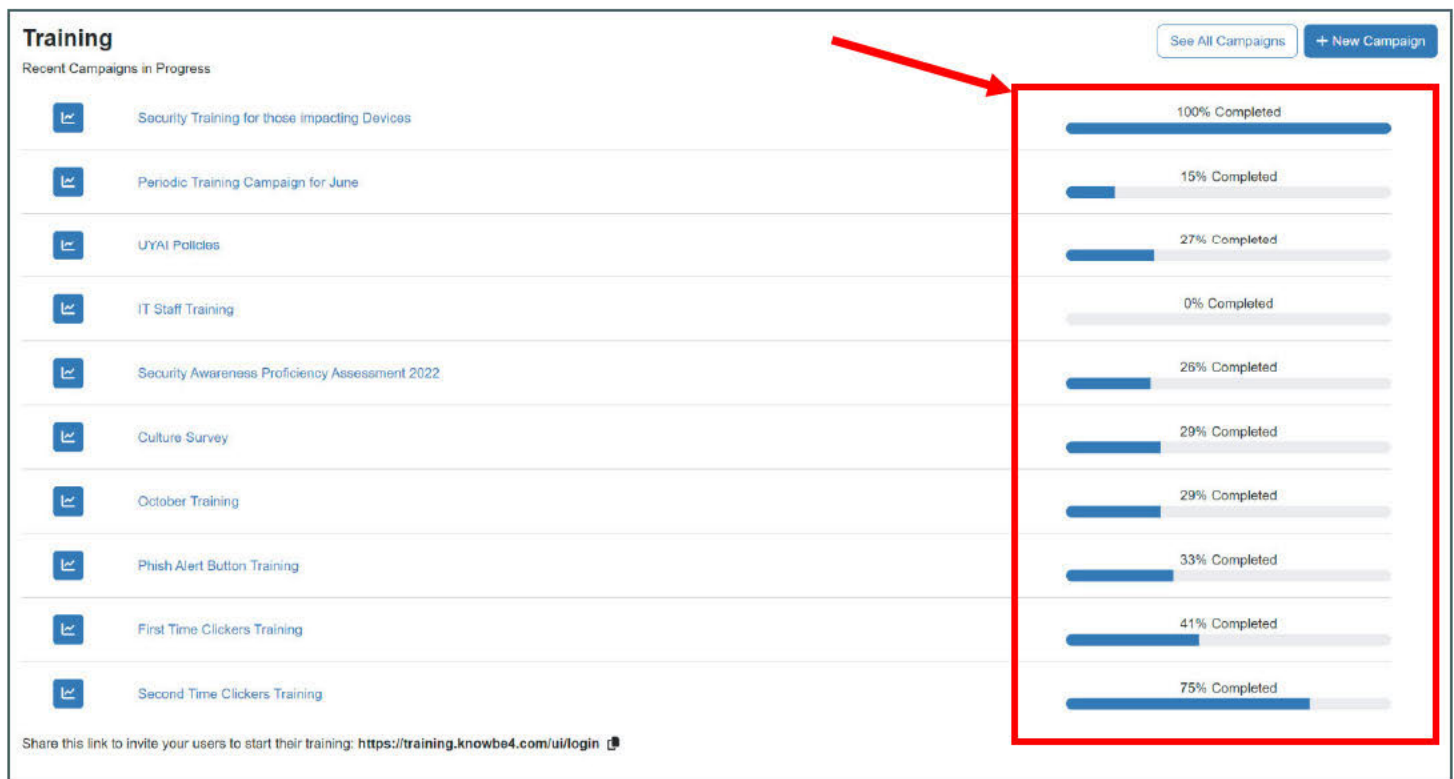
- The organization's current risk score is [REDACTED], which is above the desired range of 0-20, indicating a higher level of vulnerability and exposure to potential security threats.
- Industry Phish-prone %: [REDACTED]% - This represents the average percentage of users within the industry who are susceptible to phishing attacks.



Organization's Risk Score and Phishing Security Test Results Provided by KnowBe4

<https://training.knowbe4.com/app/dashboard>

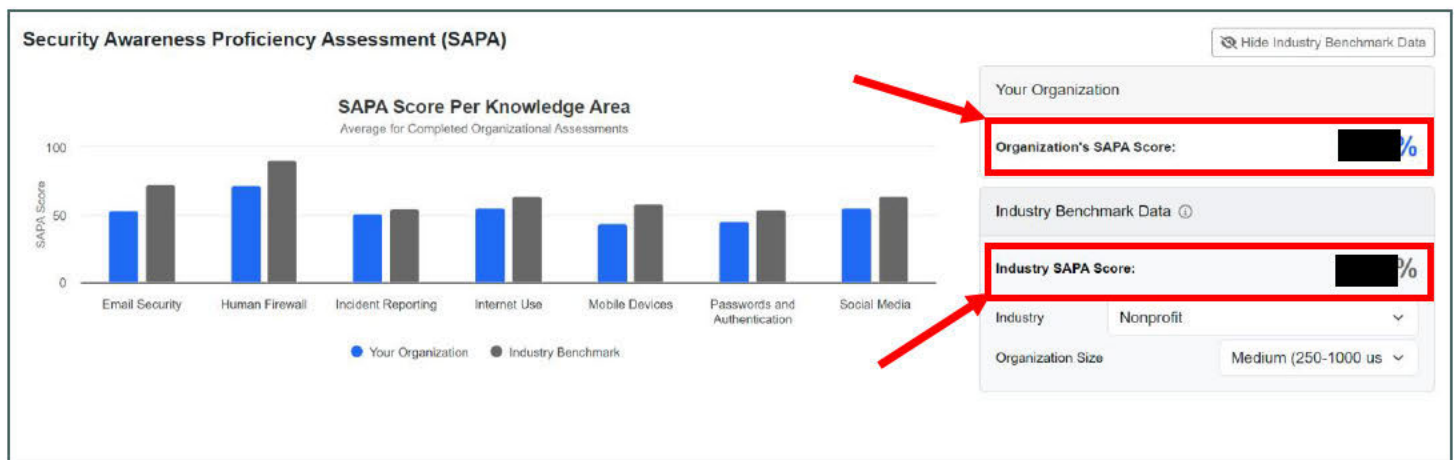
- The overall low completion rates for security awareness and IT training programs, particularly in high-risk areas like phishing and scam prevention, indicate a significant lack of engagement and follow-through in these initiatives.



Users Training Completion Rates Provided by KnowBe4

<https://training.knowbe4.com/app/dashboard>

- The organization's Security Awareness Proficiency Assessment (SAPA) score is ████%, which is below the industry benchmark of ████% for nonprofits of similar size. This indicates a need for improvement in overall security awareness among employees.



Security Awareness Proficiency Assessment Provided by KnowBe4

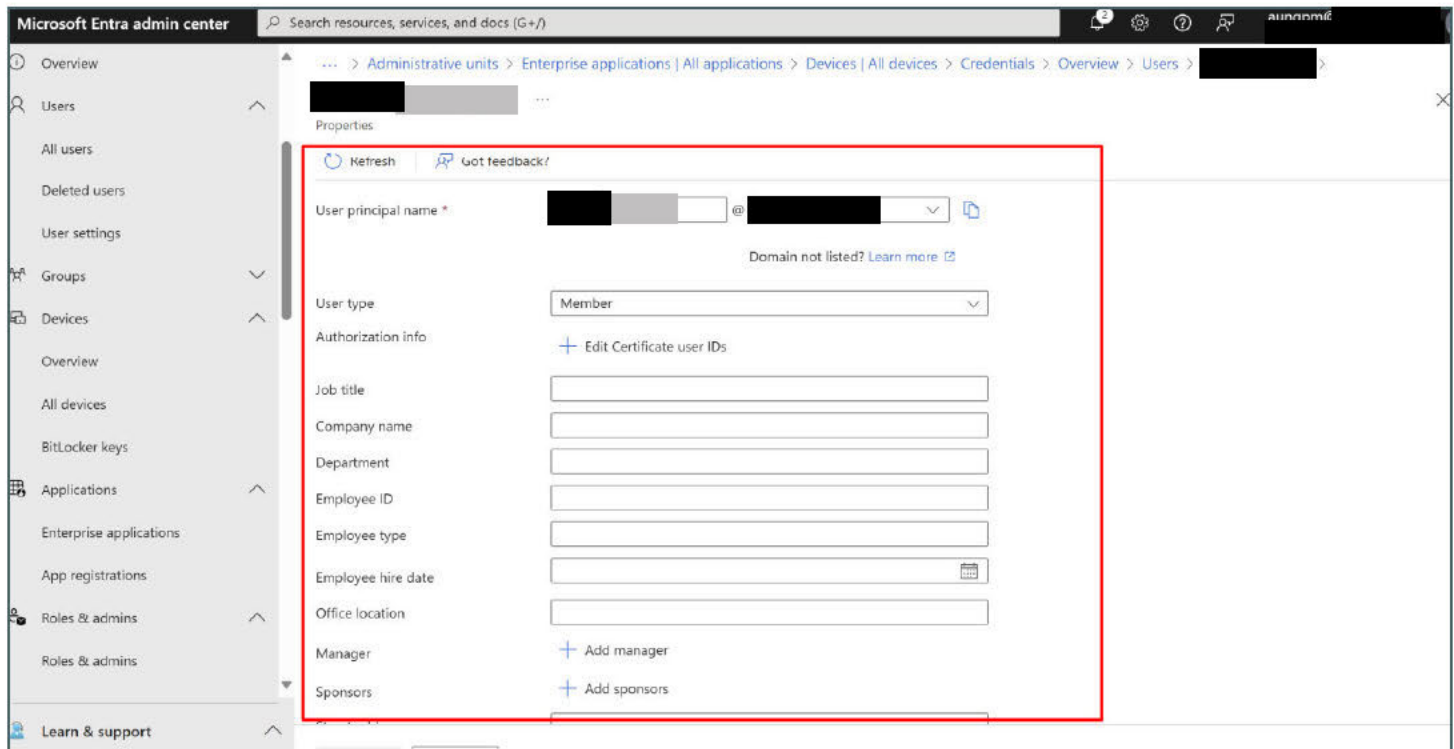
<https://training.knowbe4.com/app/dashboard>

**Recommendations**

- Prioritize the implementation of comprehensive security measures, including enhanced training, stricter access controls, and improved incident response plans, to reduce the organization's risk score.
- Increase efforts to improve training completion rates by incorporating mandatory participation policies for all employees, with a focus on critical areas like phishing prevention and security awareness.
- Enforce completion of these trainings through supervisors, and incorporate training completion rates into employee performance evaluations by HR.
- Consider integrating interactive and engaging training methods, such as gamified learning or real-world simulations, to boost participation and retention.
- Implement comprehensive policies and training for secure document and equipment disposal, educate employees on the risks of unknown USB devices, phishing threats, shoulder surfing, and the dangers of keeping passwords in easily accessible notes, and reinforce practices to prevent unauthorized access through piggybacking, tailgating, and dumpster diving, while ensuring secure disposal methods are in place.
- Conduct regular risk assessments to identify and address areas of vulnerability.

Additional Recommendations for Improvement

- **Utilize Microsoft Entra ID More Effectively:** Start using the domain for better device management by joining all devices to the domain. Implement consistent naming conventions for all organizational devices. Fill out comprehensive user information in Entra ID, including details such as Job Title, Department, Office Location, Manager, and contact details.



Microsoft Entra admin center

Search resources, services, and docs (G+/)

Overview

Administrative units > Enterprise applications > All applications > Devices > All devices > Credentials > Overview > Users > [Redacted]

Properties

Refresh Got feedback?

User principal name * [Redacted] @ [Redacted] Domain not listed? [Learn more](#)

User type Member

Authorization info + Edit Certificate user IDs

Job title

Company name

Department

Employee ID

Employee type

Employee hire date

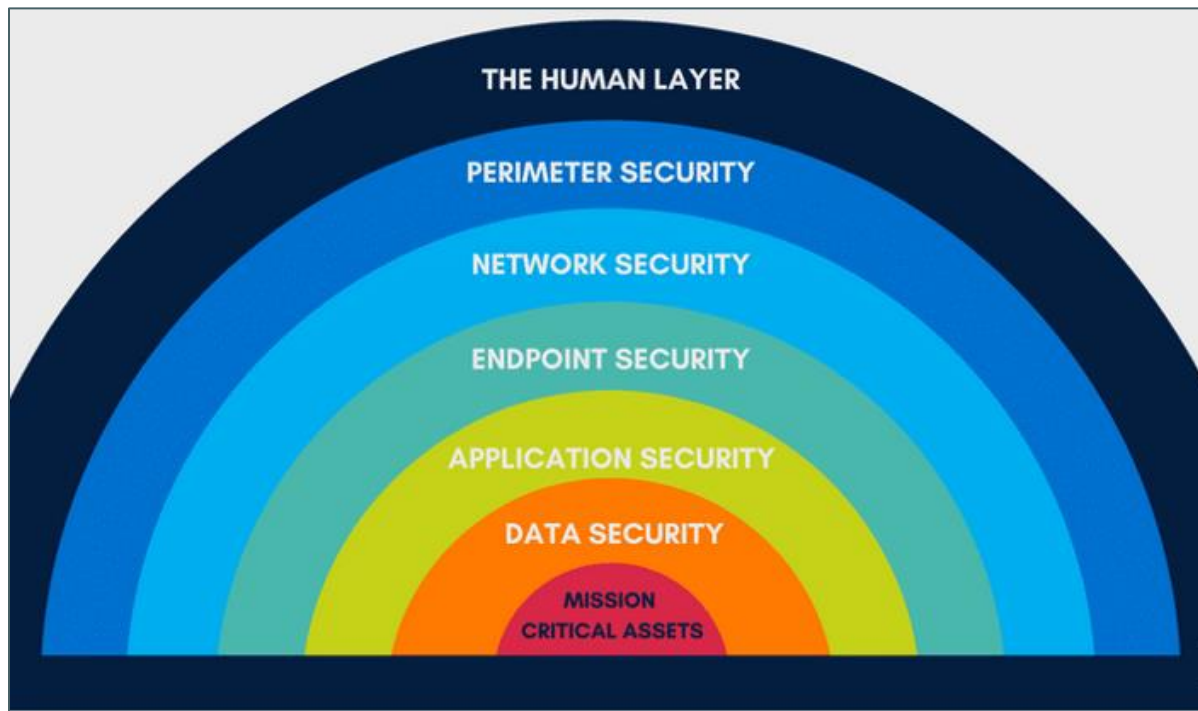
Office location

Manager + Add manager

Sponsors + Add sponsors

Incomplete User Information in Microsoft Entra ID

- **Implement Comprehensive Shared Drive:** Establish a centralized shared drive to improve storage management and accessibility of organizational data.
- **Enhance Onboarding and Offboarding Procedures:** Develop and implement IT procedures for onboarding and offboarding employees to ensure a smooth transition and secure handling of access rights.
- **Remote Support Tools:** Ensure TeamViewer is available on all organizational devices (PCs and mobile phones). Consider alternative remote support tools if TeamViewer encounters issues.
- **IT Equipment and Device Acquisition:** Acquire necessary IT equipment and devices, including network testing tools such as Ethernet strippers and network testers, to ensure efficient troubleshooting and maintenance.
- **Purchasing and Ordering Procedures:** Create a comprehensive procedure for IT device procurement, including a structured process for proposals and approvals.
- **Implement Multi-layered Security:** Avoid reliance on a single layer of security. Implement a multi-layered security approach that includes measures beyond just using MacOS devices, as they can still be vulnerable. Consider additional layers such as advanced threat protection, network segmentation, and regular security updates.



Layers of Security: Implementing Multiple Security Measures for Comprehensive Protection

- **Conduct Regular Security and Risk Assessments:** Perform ongoing security and risk assessments to evaluate and enhance data privacy policies and protection measures for data in transit, data at rest, and data in use:
 - **Data at Rest:** Protect stored data with encryption, access controls, and secure storage practices.
 - **Data in Transit:** Use encryption protocols like TLS/SSL and secure VPNs to safeguard data during transmission.
 - **Data in Use:** Ensure data being processed or accessed is protected against unauthorized access and misuse.
- **Address Key Security Areas:**
 - **User Data and Privacy:** Implement measures to protect user data and privacy.
 - **Governance, Risk, and Compliance:** Ensure adherence to relevant regulations and standards.
 - **Email Security:** Strengthen defenses against email-based threats.
 - **Software Security:** Regularly update and secure software applications.
 - **Hardware Security:** Protect physical devices from unauthorized access or tampering.
 - **Physical or Perimeter Security:** Enhance physical security controls to protect organizational assets.
 - **Network Security:** Implement robust network security measures to safeguard against threats.



END